中国研究生网络安全创新大赛

作品报告

作品名称：PrivEdge 多源 LDP 摘要的抗投毒可信交换

提交日期：2026 年 10 月 17 日

填写说明

1. 所有参赛项目必须为一个基本完整的设计。作品报告书旨在能够清晰准确地阐述（或图示）该参赛队的参赛项目（或方案）。

2. 作品报告采用A4纸撰写。除标题外，所有内容必需为宋体、小四号字、1.5倍行距。

3. 作品报告中各项目说明文字部分仅供参考，作品报告书撰写完毕后，请删除所有说明文字。(本页不删除)

4. 作品报告模板里已经列的内容仅供参考，作者可以在此基础上增加内容或对文档结构进行微调。

5. 为保证网评的公平、公正，作品报告中应避免出现作者所在学校、院系和指导教师等泄露身份的信息。一经发现，取消作品参赛资格。

目　　录

摘要.....1

第一章 作品概述.....2

1.1 研究背景.....2

1.2 相关工作.....2

1.2.1 LDP 频率估计与 Top K 识别.....2

1.2.2 LDP 投毒攻击与防御.....3

1.2.3 arXiv 2506.02156 与恶意报告检测.....3

1.2.4 已有鲁棒聚合.....3

1.2.5 隐私预算审计与协议验证.....4

1.3 作品贡献.....5

1.4 应用场景.....5

第二章 作品设计与实现.....6

2.1 问题模型.....6

2.2 安全模型.....6

2.3 设计目标.....7

2.4 系统总体框架.....8

2.5 方案设计思路及原理.....9

2.5.1 LDP 摘要发布.....9

2.5.2 发布端伪造用户检测.....11

2.5.3 网关抗投毒融合.....11

2.5.4 签名发布协议与预算账本.....13

2.5.5 三态输出与解释.....15

2.6 安全性分析.....16

2.6.1 隐私性分析.....16

2.6.2 容错定理与适用条件.....17

2.6.3 ProVerif 形式化验证.....18

2.6.4 设计约束与实现验证.....19

2.7 前端设计与实现.....19
2.7.1 总览与冷启动预测.....20
2.7.2 攻防实验室与账本审计.....21
2.7.3 实验中心与证据展示.....23
2.8 后端设计与实现.....24
2.8.1 服务接口与模块实现.....25
2.8.2 运行流程与实现边界.....26
第三章 作品测试与分析.....28
3.1 测试方案.....28
3.1.1 系统功能与接口测试.....28
3.1.2 算法实验与对照设计.....29
3.1.3 程序验收与复现范围.....29
3.2 测试环境.....30
3.3 数据集与评价标准.....30
3.3.1 数据集与预处理.....31
3.3.2 指标与统计方法.....31
3.4 结果展示与分析.....32
3.4.1 四方法描述性对照.....32
3.4.2 分层防线与权重封顶.....35
3.4.3 隐私效用与参数敏感性.....37
3.4.4 协议异常路径与模型验证.....40
3.4.5 当前程序验证.....41
3.4.6 完整应用流程.....42
3.4.7 旧管线通信与计算开销.....42
第四章 创新性说明.....44
4.1 按可见信息分层的两层抗投毒.....44
4.2 多源支持与数值影响约束.....44
4.3 签名登记与使用绑定及可解释失败.....45

第五章 总结.....46
5.1 已完成能力.....46
5.2 技术局限与后续研究.....46
参考文献.....47
附录 A 完整证明与条件核对.....49
附录 B 结论与证据定位.....52
附录 C 当前程序运行与复现.....53
C.1 程序版本与三步启动.....53
C.2 统计复现的起点与限制.....53
附录 D 来源与第三方许可.....55
D.1 原创范围与代码来源.....55
D.2 数据来源与许可.....56
D.3 分发组件与未完成确认.....57

摘要

多方共享本地差分隐私（LDP）统计摘要时，扰动机制保护个人输入，却不能阻止伪造报告；数字签名确认发布来源，也不能保证合法发布者提交的数值诚实。PrivEdge 面向这一缺口，实现多源 LDP 摘要的抗投毒可信交换。系统按信息可见性设置两层防御：发布端从扰动报告中筛查异常联合支持，网关仅基于 Top-m 摘要组合多源支持、留一截尾与权重封顶；签名、窗口、角色和预算登记绑定摘要的发布与实际使用，链损坏触发拒答。以新区域品类推断为例，作品在三套数据上验证统计效用与攻击影响，并以协议模型和程序测试核对交换行为。TRD 中 ε=1、m=20、单源伪造数为诚实数 10%的场景下，既有五种子实验的攻击目标入榜比例由 0.9030 降至 0；四方法描述性对照同时保留无攻击无普遍优势、部分鲁棒基线更优及双源合谋残余风险。系统输出检查通过、降级或拒答及原因，检查通过不代表预测准确。理论影响界依赖留一诚实多数等条件，原型验证不替代真实分布式部署。

关键词：本地差分隐私；多源摘要；数据投毒防御；可信交换；可审计原型

第一章 作品概述

1.1 研究背景

多个组织希望共享统计规律，却不愿直接交换个人行为记录。本地差分隐私允许用户先扰动类别再上报，但也使接收方难以区分诚实随机化和刻意构造的报告。与此同时，持有合法密钥的发布者可以生成验签正确的虚假摘要。隐私保护、来源认证和统计可信性因此需要分别处理。

PrivEdge 解决的具体问题是：目标网关只接收多个来源的稀疏 Top-m 摘要时，如何限制恶意来源对候选品类和融合分数的影响，并说明哪些摘要被使用、哪些检查失败。作品以多源 LDP 摘要的抗投毒可信交换为主线，新区域热门品类推断只是检验这条交换流程的应用例子。

设计的关键约束是信息不对称。发布端能查看用户级扰动报告，可以筛查异常共同支持；网关无法回看这些报告，只能利用摘要间的支持关系与数值分布。系统据此在两处设置防线，并用签名登记和实际使用内容绑定连接两层。最终输出检查结论、Top-k 及审计原因，离线预测指标另行评价。

1.2 相关工作

相关研究分别解决隐私估计、扰动报告投毒、鲁棒聚合或协议认证。下面按它们能够观察的信息和提供的保证定位本作品，既注明继承的方法，也说明组合设计的新增范围。

1.2.1 LDP 频率估计与 Top K 识别

本地差分隐私（Local Differential Privacy，LDP）将随机化放在数据产生端，使汇聚方只接触扰动报告。RAPPOR 展示了可聚合的随机响应工程路径，Succinct Histograms 研究大域稀疏频率发布，Wang 等系统比较了广义随机响应、OUE 和 OLH 并给出频率估计的误差分析[1,2,3]。这些工作的共同对象是诚实用户报告；PrivEdge 面对的输入还包含多个区域、Top-m 删失和来源级攻击。

OLH 适合大类别域，是因为单条报告的通信量不随类别总数线性增长。PrivEdge 的实际改动在于把估计结果组织成带窗口、来源、样本数、方差和签名的稀疏摘要，并把后续的来源准入与鲁棒融合纳入同一条可审计流水线。它没有声称重新提出 OLH 或继承其全部重频项识别算法[12]。

1.2.2 LDP 投毒攻击与防御

LDP 让汇聚方不能从单条报告恢复真实类别，因而伪造用户可以直接提交桶值而不经过诚实用户的随机化过程。Cao、Jia 和 Gong 系统研究了面向 kRR、OUE 和 OLH 的最大增益攻击（MGA），并讨论了归一化和频繁项集检测等防御[4]。该威胁模型是 PrivEdge 发布端检测的来源之一，但论文中的攻击优化问题、协议参数和实验结论不能自动转化为本项目保证。

本项目使用 MGA 风格的有界随机搜索构造伪造报告，具体攻击预算和比例见 3.1.2。发布端筛查和网关摘要级防御处理不同输入：前者不能约束被攻破发布者直接伪造摘要，后者无法回溯用户级报告。

1.2.3 arXiv 2506.02156 与恶意报告检测

Li 等人的 arXiv:2506.02156（CCS 2025）工作研究了 LDP 投毒缓解，提出 Diffstats、ASD 和 RSN 等组件，用报告支持项数和频率统计识别候选伪造用户，并对异常频段进行检测或归一化[5]。这些方法提供了可比较的统计检测思路，其检测和效用结果依赖原论文的数据协议、攻击设置及阈值校准。PrivEdge 采用下述联合支持检测流程，检测能力以本项目实验衡量。

本作品没有实现该论文的 Diffstats、ASD 或 RSN，也没有把其效用恢复结论当作本队结果。当前发布端采用联合支持项集启发式，具体过程及阈值限制见 2.5.2。该论文是相关研究参照，作品的实验数据、程序实现和影响界以本报告对应证据为准。

1.2.4 已有鲁棒聚合

中位数、坐标截尾均值和 Krum 是分布式学习中常见的拜占庭鲁棒聚合。Yin 等在梯度向量模型下分析了截尾均值的误差和恶意节点条件，Blanchard 等提出基于梯度向量距离选择代表节点的 Krum[6,7]。两类方法通常接收同维、完整的节点向量，而

PrivEdge 接收各区域只发布 Top-m 的稀疏频率摘要;未发布项既有统计缺失也有业务含义，不能直接套用梯度定理。

COMPARE_V1 中的 trimmed_frequency 是本地经验基线：逐品类收集来源频率，缺失项补 0，排序后两端各删一项，再对中间值取均值并形成 Top-k。它只借鉴坐标截尾的聚合形式，不是 Yin 等论文实现的复现，且其缺失补 0、来源数和攻击模型不满足原论文定理的完整条件。Krum 需要稳定的全向量距离和足够节点数；稀疏 Top-m 摘要可通过补零构造成距离向量，但缺失语义和距离尺度需另作设计，当前四方法对照未纳入该额外适配。

PrivEdge 另组合原始来源支持、留一截尾与权重封顶，其适用条件与分数界见 2.5.3、2.6.2 及附录 A。

1.2.5 隐私预算审计与协议验证

差分隐私的组合性质要求在重复访问同一用户数据时核算累计隐私损失[8]。PrivEdge 账本按源与窗口记录发布预算，并拒绝超过策略上限的登记。不同窗口用户集合不相交是部署假设，系统没有实现跨窗口用户身份核查。
Certificate Transparency 通过可验证日志支持公开检查[10]。本作品使用顺序哈希链与摘要绑定提供原型内的一致性检查；尚未实现独立见证者、公开一致性证明或防日志分叉机制，因此不将两者的审计保证等同。ProVerif 可在符号攻击模型下分析认证与保密性质[9]，本作品据此核对发布、账本与准入的绑定关系，并以实现测试补充数值检查等模型之外的行为。

表 1-1 相关方法与 PrivEdge 的关系

研究方向	已有方法及输入	本作品使用与新增范围
LDP 估计	OLH 等[1－3]；用户级随机报告	沿用 OLH 结构；将稀疏摘要接入带来源、窗口和预算登记的交换流程。
报告投毒检测	MGA 与频繁项集思路[4]；Diffstats、ASD、RSN[5]	参考威胁及统计检测思想；实现本地联合支持启发式，不声称复现上述检测器。

研究方向	已有方法及输入	本作品使用与新增范围
鲁棒聚合	坐标截尾与 Krum[6,7]；完整梯度向量	对照采用缺失补零的截尾适配；本作品组合原始支持、留一截尾和权重封顶。
审计与协议	隐私组合[8]、ProVerif[9]、透明日志[10]	约束签名登记与实际使用；内存哈希链不等同分布式透明日志。

1.3 作品贡献

第一，按可见信息分层设置抗投毒防线。发布端针对扰动报告的异常共同支持进行筛查；网关针对合法签名下的摘要作恶限制跨源影响，两者覆盖不同攻击入口。

第二，同时约束候选支持与数值影响。当恶意来源数 f<t 时，原始 Top-m 支持门槛排除从未被诚实来源发布的新增项；留一截尾和权重封顶约束极端频率与谎报方差。给出各自的条件性保证，并用四方法对照保留代价和失效场景。

第三，将签名登记与使用内容绑定，并输出可解释失败。注册角色、签名窗口、预算与账本摘要共同参与准入；链损坏进入拒答，单份摘要拒收保留原因。符号模型、程序检查和页面证据分别支撑协议逻辑与实现行为。

三项贡献的具体机制在第二章展开，统计和系统证据在第三章报告，第四章归纳与已有能力的差异及适用范围。

1.4 应用场景

以新区域品类推断为例，已有区域分别发布经过 LDP 扰动的品类摘要，新区域网关在不接收个人原始类别的前提下形成 Top-10 建议。离线评价使用目标区域真实分布衡量排序质量，目标真值不输入预测。此例可说明摘要交换的可行性；选品收益、库存和地域迁移效果尚需真实业务试验。

第二章 作品设计与实现

2.1 问题模型

设已运营区域构成数据源集合 S，每个源在窗口 W 内收集用户扰动报告。用户贡献一个类别值，采用 OLH 生成哈希种子与桶值。区域发布者进行频率估计与报告过滤，发布 Top-m 条目，每条包含类别编号、频率与方差；目标网关不接收逐用户原始报告。目标区域 T 在推理时只使用其他源提交的摘要，输出 Top-k 类别、支持源数量、三态和原因码。离线实验可以读取 T 的真实分布用于打分，但该分布没有作为 admit、decide 或 predict 的输入。演示引擎在同一进程中读取标准表并模拟各角色，目标真值与预测结果的对照单独放在 evaluation 字段，不宣称已部署真实终端采集。

对象或符号	含义与实现对应
源与目标	源为非目标区域；演示引擎按 target 剔除该区域后构造 sources。
类别域 D	类别编号及其版本生成 domain_hash；网关要求域一致。
窗口 W	签名正文内的 window_id；网关检查 allowed_windows。演示窗口为进程内编号。
ε 与用户数	扰动预算与摘要中的 n_users；账本和网关检查合法性与策略边界。
Top-m 与 Top-k	m 控制摘要截断，k 控制输出；控制台默认 m=40，已登记主实验使用 m=20。
目标真值	仅用于离线评价及展示标注，不能用于调参、选源、映射或推理。

2.2 安全模型

系统区分伪造用户、被攻破发布者和网络消息攻击者，并明确注册表、账本及宿主的信任假设。签名认证和统计防御分别应对不同能力，不能互相替代。

角色	能力与目标	信任边界
伪造用户	构造 OLH 输出域内的报告，推动攻击目标类别。	发布端按报告统计检测；验证不覆盖任意未知攻击。
被攻破发布者	持合法密钥，伪造频率/方差、隐藏热门或提交多份摘要。	签名不能识别数值是否诚实；由摘要级防御约束。
网络攻击者或第三方	篡改、旧窗口重放、未注册密钥冒充、冒名登记。	验签、窗口与主体角色绑定、账本核对提供检查。
汇聚方与网关	按协议处理，可能尝试推断个体信息。	LDP 保护依赖扰动与参与假设；不保证群体推断安全。
注册表与账本服务	提供主体角色公钥与登记记录。	在模型中视为诚实，密钥泄露例外见形式化性质。
演示宿主环境	能访问本地标准表和内存状态。	同进程模拟不构成针对宿主被攻破的隔离保证。

协议验签仅证明消息与注册密钥的绑定。统计防御的保证还取决于诚实源数量、支持阈值、权重与异质性等条件；支持规则不能保证已有类别的名次不被改变。用户参与隐私、群体推断以及宿主完全被攻破不在当前验证范围。

2.3 设计目标

设计目标不是在所有数据上提高无攻击精度，而是在保留可用统计效用的同时，对不同攻击入口建立可检查的防线。下表给出从威胁到证据的对应关系，后文沿同一路径说明实现。

表 2-1 威胁 可见信息 防线与验证位置

威胁或条件	处理方可见信息	处理与输出	验证位置
伪造用户报告	发布端可见 OLH 报告	联合支持筛查后重新估计	2.5.2；3.4.2

威胁或条件	处理方可见信息	处理与输出	验证位置
合法密钥伪造频率或方差	网关仅见多源 Top-m 摘要	支持门槛、留一截尾、封顶权重	2.5.3；2.6.2；3.4.1
篡改、冒名、旧窗口	签名、角色注册与登记摘要	拒收不合格摘要并保留原因	2.5.4；3.4.4
链损坏或可用来源不足	账本链、准入集与候选集	拒答；不生成伪推荐	2.5.5；3.4.5
隐私与实际效用	固定参与集合与离线目标真值	ε-LDP 论证；独立评价排序	2.6.1；3.4.3

2.4 系统总体框架

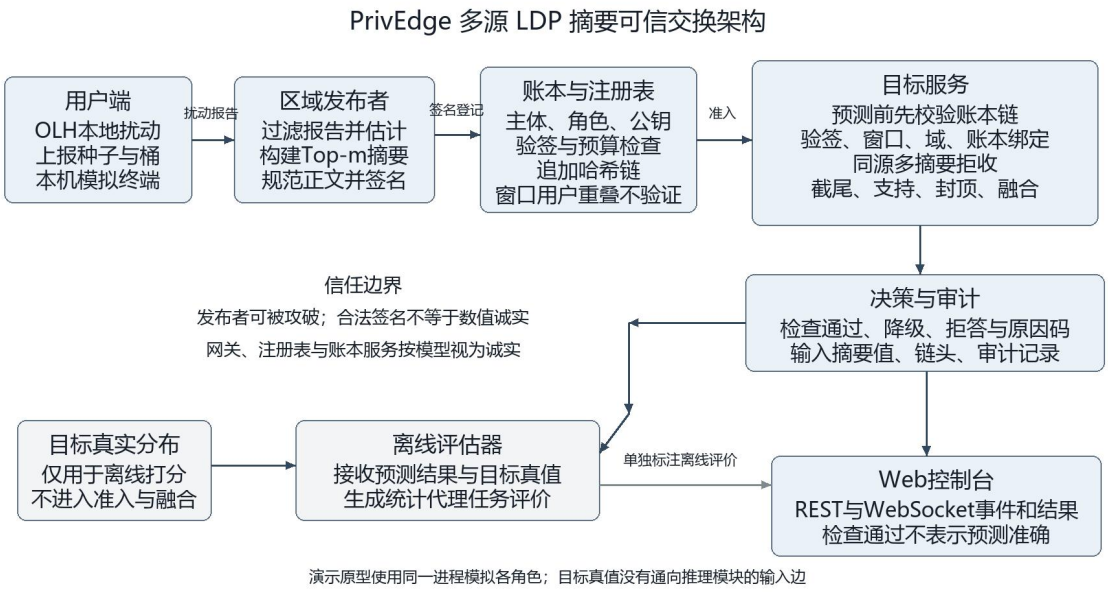


图 2-1 多源摘要可信交换与独立离线评估流

正常业务流从用户扰动报告开始，经发布端过滤和估计构建摘要，完成签名及登记后进入目标服务。目标服务先校验账本链，再调用网关准入；被接受的摘要交给鲁棒融合与三态决策。输入摘要值、账本链头、准入结果和决策形成带哈希的审计记录。REST 与 WebSocket 调用同一演示引擎。WebSocket 输出 collect、release、ledger、admit/reject、decision 等事件，再输出最终结果或错误。实验中心另外读取已登记

运行，不把现场单次演示替代预注册实验。离线评估只接收预测结果与目标真值，评价标签不反向改变预测。

模块	实际职责
ldp / robust / pipeline	扰动、报告过滤、估计、摘要与角色管线。
envelope / keys	规范化正文、Ed25519 签名、主体角色密钥注册与验证。
ledger / gateway	登记前验签、预算与链检查，摘要合法性和账本绑定准入。
decision / algorithms	支持规则、截尾、封顶后的融合与三态。
server / web	请求、实时事件、结果展示与演示审计；原型没有登录机制。
experiments / evidence	实验运行与登记证据读取；目标真值只在离线评分使用。

2.5 方案设计思路及原理

作品按用户扰动、发布端筛查与摘要构造、网关准入与融合、结果解释分层实现。算法层只处理其可访问的报告或摘要；签名、预算与三态把这些处理接入交换流程。

2.5.1 LDP 摘要发布

设一个发布窗口保留 N 条 OLH 报告，每条报告包含随机种子 a 和桶值 y。发布端对类别 i 检查报告是否支持其哈希桶，所得支持数记为c_i。代码根据 ε 计算 g、p 和 q，并先生成原始计数估计，再生成频率和方差；这里的 N 是过滤后的剩余报告数。

$$\hat{C}_i = \frac{c_i - Nq}{p - q}, \quad p = \frac{e^{\varepsilon}}{e^{\varepsilon} + g - 1}, \quad r = \frac{1}{e^{\varepsilon} + g - 1}, \quad q = 1/g$$

$$f_i = max(0, \hat{C}_i)/N$$

$$\widehat{Var}(\hat{C}_i) = max\{[C_i p(1-p) + (N-C_i)q(1-q)]/(p-q)^2,\ 10^{-12}\},\quad C_i = clip(\hat{C}_i, 0, N)$$

方差使用插件估计：先把原始计数估计截到[0,N]得到$\tilde{C}_i$，再代入随机响应方差表达式并设置数值下限10^{-12}；发布频率方差为该计数方差除以 N^2。它是未选择类别时的条件插件量，不是经过 Top-m 选择和联合筛查后的精确置信区间。实际发布只保留按原始计数排序的 Top-m 项，频率做非负截断但不再额外上限到 1。

LDP 摘要发布

输入：用户类别、 ε 、独立随机数、类别域哈希、Top-m 和窗口元数据。

1. 在设备端为每个用户类别抽取 OLH 种子并生成桶值；设备端不上传原始类别。
2. 发布端按候选类别计算支持数，得到原始计数、非负频率和插件方差。
3. defense 开启时先在原报告上执行初始聚合和联合支持筛查;过滤后重新聚合。
4. 按原始反偏置计数稳定排序并保留 Top-m，再生成非负频率及方差/N^2。
5. 写入 source_id、window_id、N、 ε 、机制和哈希族，对规范化摘要签名并登记账本。

稠密化与实际融合须分开。网关统计 peer 截尾尺度时，对未发布频率使用半个非负已发布最小值的填充；最终加权融合时未发布项的输入是 0。签名证明来源、窗口和内容未被篡改，不证明发布者没有主动作恶。

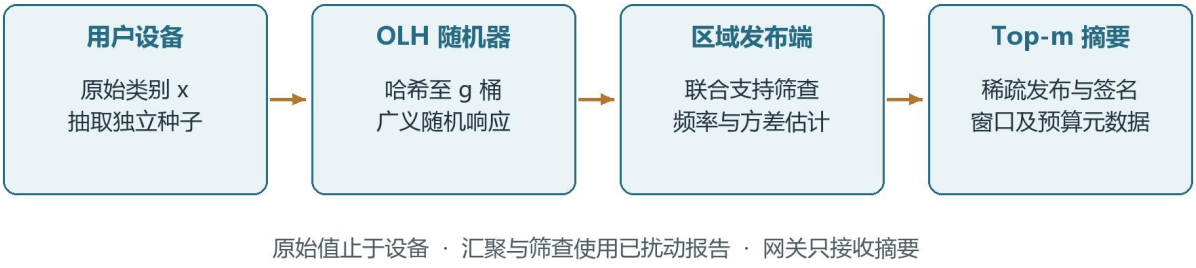


图 2-2　从设备端扰动到可审计 Top-m 摘要的发布流程

2.5.2 发布端伪造用户检测

检测器在初始聚合后取前 min(2m,d)个候选类别，并构造候选类别的逐报告支持矩阵。对项集 T，J(T)表示同时支持 T 的报告数；a(T)把各项的非负频率估计相加后截到 1，作为报告属于目标集合的插件比例。理想独立碰撞模型下的期望联合支持和标准化超额分别为：

$$E_T = N[a(T)pq^{|T|-1} + (1-a(T))q^{|T|}]$$

$$z_T = [J(T) - E(T)]/\sqrt{max(E(T), 1)}$$

实现先枚举所有候选项对，选择 z 超过 6 且最大的项对；随后按候选原顺序逐项尝试扩展，只考虑新 z 仍超过 6 且联合支持超额至少保留当前超额 0.7 倍的项，并从合格扩展中选择超额最大的一个加入，最大项集长度为 8。若没有合格项对，则不删除任何报告。若有最终项集，删除同时支持完整项集的报告，记录项集、z 和删除数量，并在发布前重新聚合。

联合支持伪造用户检测

候选集 P←初始估计中计数最高的 min(2m,d)个类别；根据 P 建立支持矩阵。

对 P 中的每一对(a,b)：计算 J、E 和 z；若 z>6，保留当前最大者。

令 T 为最佳项对；按 P 原序扫描 i∈P\T，从 z>6 且 excess_new≥0.7·excess_old 的扩展中选超额最大者；重复至无合格扩展或|T|=8。

令 bad 为同时支持 T 的报告；输出 R\bad 及审计记录。若无最佳项对，输出原报告。

该检测是针对共同支持攻击结构的局部启发式。它不是 Cao 等 FIAD 的完整复现，也不是 Li 等 Diffstats、ASD 或 RSN 的实现。因为候选选择、插件期望估计和多次搜索均使用同批数据，z=6 不能解释为统一显著性阈值或零误报保证。MGA 实现最大化的是目标类别在同一桶中的支持数，不能保证每个伪造报告同时支持全部目标项。

2.5.3 网关抗投毒融合

网关先校验账本哈希链；链断裂时拒答。随后逐份检查签名、窗口、来源登记、预算和同源重复，拒收不合格摘要；若同一来源提交多份有效摘要，则拒收该来源全

部摘要，仍使用其他已准入来源继续决策。来源 s 发布的 Top-m 项集合记为 M_s，品类 i 的原始来源支持数为 sup(i)；默认 t=2。该支持数在截尾前统计，截尾不删除品类。

$$A_t = \{i : sup(i) = |\{s : i \in M_s\}| \geq t\}$$

无上下文路径中，网关先在所有已发布品类并集上逐项执行留一统计和截尾，之后才按原始支持数构造候选集合A_t。令$m_{-s,i}$为排除来源 s 后的 peer 频率中位数，$d_{-s,i}$=1.4826 • MAD，$\eta_{-s,i}$为 peer 方差中位数，$z_{s,i}$为截尾后的已发布频率（未发布项在实际融合时为 0）。未发布项的稠密填充值只进入 peer 统计，不进入最终融合。截尾上界默认 c=3、ρ=0.25，且下界为 0。异常分数只写入告警，不自动删除来源，因为跨区域真实异质性会产生未校准的偏离。

$$B_{s,i} = m_{-s,i} + c\sqrt{[\eta_{-s,i} + d_{-s,i}^2 + (\rho m_{-s,i})^2 + 10^{-10}]}, \quad \tilde{x}_{s,i}$$

$$= max\{0, min(x_{s,i}, B_{s,i})\}$$

支持筛选前，权重按每个来源已发布项的平均方差计算：先对平均方差开平方，并对所得标准不确定度设置10^{-12}下限，再取倒数。为防止来源谎报极小方差夺取全部权重，每个权重再封顶为 κ 倍留一 peer 权重中位数，默认 κ=2。截尾后对完整品类并集加权排序，再保留支持数达到 t 的候选并取前 k 项；若准入来源少于 min_sources=3，或支持过滤后返回不足 k 项，默认决策器拒答。

$$u_s = 1/max\{\sqrt{mean_i \sigma^2_{s,i}}, 10^{-12}\}, \quad \omega_s = min(u_s, \kappa \cdot median_{r \neq s}(u_r))$$

$$S_i = \Sigma_s \omega_s z_{s,i} / \Sigma_s \omega_s, \quad i \in A_t$$

网关抗投毒融合

验证账本哈希链；断裂则拒答。逐份校验摘要并拒收失败项；同一来源多份有效摘要则全部拒收该来源。

统计原始摘要中各品类的来源支持数;对已准入摘要并集逐项做留一 peer 统计和非负截尾，不删除品类。

对已发布方差均值开平方，以10^{-12}作标准不确定度下限后取倒数；再按 κ 倍 peer 权重中位数封顶。

对截尾后的完整品类并集加权排序，再过滤 sup(i)≥t 的候选A_t并取前 k 项。来源少于 min_sources=3 或过滤后候选少于 k 项则拒答；否则输出 NORMAL/DEGRADED 及原因码。

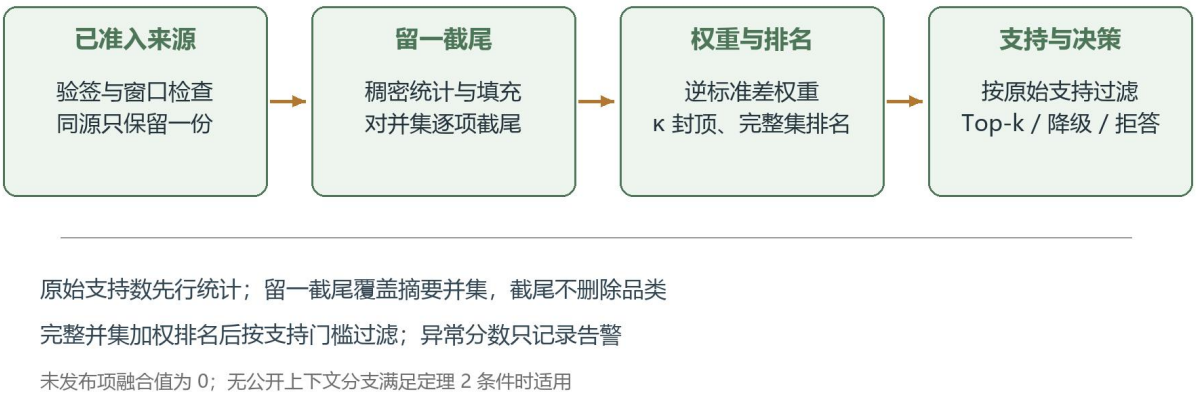


图 2-3　网关准入、支持筛选与无上下文鲁棒融合流程

含公开上下文的 censor-aware 分支使用另一套估计流程，以上步骤和后文定理不覆盖该分支。四方法对照的 PrivEdge 入口还直接构造摘要对象进行预测，比较的是发布端筛查、支持规则、截尾和权重封顶的端到端组合，不是只替换一个平均公式。

2.5.4 签名发布协议与预算账本

ReleaseEnvelope 将发布源、窗口、类别域、机制及哈希族、隐私预算、用户数、Top-m 条目、尾部界与过滤说明封装为一个信封。seal 在正文中补充 key_id、created_at 与随机 nonce，再对排序键、紧凑分隔符、UTF-8 编码的规范化 JSON 签名（Ed25519[11]）；signature 字段自身不属于被签正文。登记摘要值 digest 同时绑定正文和签名。

字段组	包含字段	用途
发布身份	release_id、source_id、key_id、version	区分记录、发布主体、密钥和信封版本。
窗口与类别域	window_id、domain_hash	限制允许窗口与同一类别编号语义。

字段组	包含字段	用途
机制与预算	mechanism、hash_family、epsilon、n_users	标明扰动机制、预算和报告规模。
统计内容	top_m、items、tail_bound、defense	items 包含 category/frequency/variance，均属于签名正文。
时间与抗重复	created_at、nonce	标明时间并辅助重复登记检查；时间字段不替代窗口策略。
签名	signature	Ed25519 签名；登记 digest 另包含该签名。

密钥注册表按 key_id 查找公钥、允许主体和角色。账本登记时首先核对签名与 source 角色，再拒绝重复编号和 nonce，检查正整数用户数及正的有限 ε，并累计该源该窗口的预算。检查通过后追加包含 prev_hash 的条目，计算 entry_hash，更新累计值。Publisher.release 提前检查预算，Ledger.append 在实际登记时再次检查。

目标服务在预测前遍历账本检查链接与条目哈希；不一致时直接生成 REFUSED 及 LEDGER_CORRUPTED，不进入正常准入。链一致时，网关依次检查签名与主体角色、类别域、允许窗口、ε 和用户数边界、条目合法性，以及登记存在性和 digest 一致性。重复摘要不重复计入；同一源在本请求中提供多份不同的有效摘要时，这些有效摘要全部拒收，以避免一源多计。

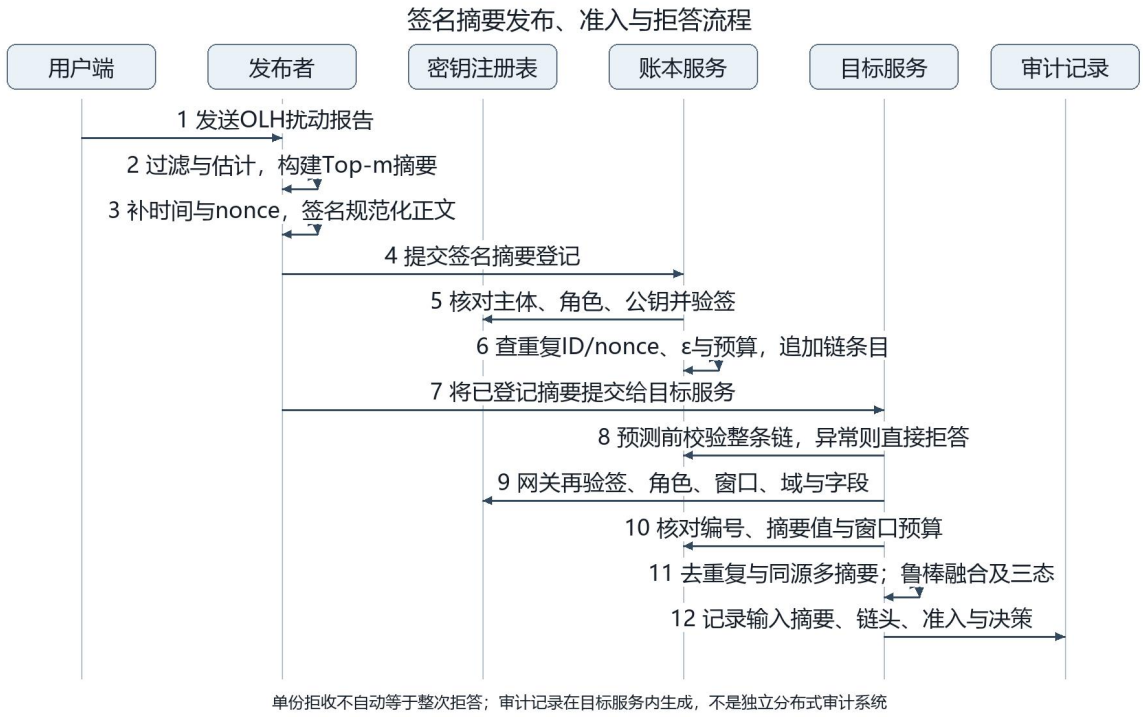


图 2-4 签名发布与预测前账本检查流程

重放检查包括重复登记、同请求重复输入和旧窗口限制；协议允许在新的预测请求中再次使用仍属于允许窗口的有效摘要，不能将此说成禁止所有跨请求复用。单份摘要拒收也不自动导致整次预测拒答，是否拒答还由接受源数、候选数与其他决策条件决定。

预算账本按“源＋窗口”核算，并不能识别不同窗口是否包含同一用户。跨窗口不累计隐私损失依赖用户集合不相交等部署假设。顺序哈希链可发现未同步重算哈希的条目改动或链链接不一致；在缺少外部可信链头或见证者时，不能据此保证防止整条日志重写或分叉。演示账本在内存中，重启后清空。

2.5.5 三态输出与解释

控制台沿用后端 NORMAL、DEGRADED、REFUSED 三态，以“检查通过、降级、拒答”为主标签并保留原因码。三态表达来源准入、支持及一致性检查的结论，不构成准确度等级；Recall、NDCG 等离线效用另区展示。

检查通过或降级时展示后端实际返回的候选及告警。拒答保留原因；如后端附带部分候选，页面如实标明其不是可用推荐，不补造结果。拒收一份摘要与整次拒答分开显示，网络失败也不标为算法拒答。真实零值、未提供和不适用分别表达。

已完成结果绑定数据集、目标、参数、种子、窗口与运行编号，在同一浏览器会话中可返回查看。修改参数后旧结果标为已完成快照，运行中的旧响应不能归入新数据集。固定种子复现数值计算，窗口、时间、签名和审计编号可以变化；取消只停止后续客户端请求，不承诺终止已开始的服务计算。

2.6 安全性分析

本节分别说明固定参与集合下的 LDP 与后处理条件、无上下文融合的条件性影响界、符号协议性质及程序回归证据。不同证据覆盖不同层次，统计实验或性质检查不替代数学证明和真实协议实现测试。

2.6.1 隐私性分析

隐私分析采用固定参与集合和替换一个用户类别的邻接关系。对固定、与输入无关的哈希种子 a，若两个类别在该种子下碰撞，输出分布完全相同；若不碰撞，任一桶输出概率只可能在 p、r 之间切换，最大比值为e^{ε}。因此对联合报告(a,y)也有：

$$Pr[M(x) = (a, y)] \ / \ Pr[M(x') = (a, y)] \ \leq e^{\varepsilon}$$

该证明不需要哈希族碰撞均匀；均匀碰撞只用于把非目标桶概率近似写成 q，并推导频率估计的无偏性和方差口径。独立用户的报告集合在替换一名用户时仍满足同一个 ε 界。

依据差分隐私后处理与基本组合结论[8]，聚合、联合支持筛查、Top-m 选择、负频率截断、插件方差、序列化、签名、账本登记和网关融合都只处理已随机化报告及独立公开元数据，属于后处理，不增加该批报告的 LDP 参数。若同一用户重新随机化并发布 L 次，则按顺序组合预算至多为各次 ε 之和；跨来源或跨窗口只有在自然人集合确实不相交时才可使用并行组合。

部署条件必须单独写明：每名用户在每个计费窗口只贡献一条报告，参与集合在计费时固定，公开上下文不含未记账私有值。当前 Publisher.collect 没有自然人身份字段，n_users 只是报告条数，source_id 和 window_id 也不能发现同一用户跨组重复，因此跨组去重和预算归属属于系统治理假设，不能由代码本身证明。复用同一批已扰动报告是后处理，不应再次消耗新的用户隐私预算。

2.6.2 容错定理与适用条件

定理 1　多源支持门槛

设 n 个不同来源通过网关准入，每个候选项至少由 t 个来源发布，至多 f 个来源被攻破。候选的诚实支持数至少为：

$$honest_sup(i) \geq t - f$$

因此当 f<t 时，任何从未被诚实来源发布的项不能通过候选准入；当 f≥t 时，攻击者可以影响候选准入，但不代表该项一定进入最终 Top-k。签名只认证来源身份和内容完整性，不把恶意来源的数值变成诚实数值。

定理 2　无上下文路径的有界影响

在 context=None、winsorize=True、clip_floor=0、κ ≥1、c≥0、ρ ≥0 且 n≥3、f<(n-1)/2 时，假设每个摘要非空、类别不重复，频率有限，方差为有限正值，诚实稠密频率非负，且来源 ID 互异。令诚实来源的最大稠密频率、频率极差、最大稠密方差分别为M_i、R_i、V_i；令诚实原始权重最小值和最大值为 w、W。定义上界和恶意权重份额上界：

$$U_i = M_i + c\sqrt{[V_i + (1.4826R_i)^2 + (\rho M_i)^2 + 10^{-10}]},\quad \bar{\alpha} = f\kappa W/[(n-f)w + f\kappa W]$$

则当前批次的融合分数满足：

$$(1-\bar{\alpha})S_i^H \leq S_i \leq (1-\bar{\alpha})S_i^H + \bar{\alpha}U_i$$

其中$S_i^H = \Sigma_{h\in H}\omega_h\ z_{h,i}/\Sigma_{h\in H}\omega_h$，表示当前输入下诚实来源截尾值按实际封顶权重归一化的均值；留一 peer 统计仍受当前恶意输入影响，因此S_i^H不是无攻击反事实分数。

证明的关键是留一 peer 仍有诚实严格多数：对任意被留出的来源，peer 数为 n-1，而 f<(n-1)/2 保证中位数落在诚实值区间；同理 peer MAD 不超过诚实频率极差，peer 方差中位数不超过诚实最大方差。于是恶意来源经截尾后不超过U_i，诚实来源的非负截尾值不超过M_i。诚实来源封顶权重至少为 w，恶意来源封顶权重至多为 κ W，恶意总权重份额至多为$\bar{\alpha}$，分解融合均值得到结论。

该定理只约束当前分数的影响，不推出 Top-k 稳定性、Recall 或 NDCG 下界，也不适用于 public-context 分支、来源数不足 3、重复来源、非零截断下界、 κ <1 或

非有限方差。COMPARE_V1 的 TRD 和 Massive 满足 n≥3 并可覆盖 f=1、2；Olist 在 n=5 时只满足 f=1。$\bar{\alpha}$取 2/11 的示例还需要 W=w，仅有各源样本数相同并不足以推出该条件。

表 2-2　容错定理的条件与不覆盖情形

条件	作用	不满足时
n≥3，f<(n-1)/2	保证任一留一 peer 诚实严格多数	中位数/MAD 上界不能直接使用
context=None	对应方差加权封顶路径	public-context 分支需另证
clip_floor=0，诚实值非负	保持诚实截尾值不增加	无法使用当前区间证明
κ ≥1，w>0，方差有限正值	建立权重份额界	$\bar{\alpha}$推导不适用

2.6.3 ProVerif 形式化验证

作品使用 ProVerif 2.05 分析签名发布协议的符号模型，登记结果为 E16。攻击者可操作公开网络消息，模型同时允许一个数据源角色密钥泄露；网关、注册表与账本按协议执行。模型中的 Publish、LoggedRel 和 Accept 分别对应发布、验签登记和准入事件，表示语义抽象对应，不声称模型与 Python 程序逐行等价。

性质	验证内容与实现对应
Q1 认证、完整性和窗口绑定	接受事件对应同源同窗口发布，或该源密钥泄露；对应 seal、check_signed 及网关窗口检查。
Q2 账本绑定	实际接受内容对应已登记摘要值，即使发布者被攻破也受该绑定约束；对应 digest、find 与 LEDGER_MISMATCH。
Q5 不可代扣预算	记在某源名下的登记来自该源，保留密钥泄露例外；对应 Ledger.append 登记前验签。
Q3 上下文角色隔离	数据源密钥泄露不等于上下文角色密钥泄露；对应主体角色注册检查，属附带协议性质。

性质	验证内容与实现对应
Q4 原始数据保密	在 LDP 摘要抽象为单向函数的模型中成立；不是 ε -LDP 证明，也不度量统计推断风险。

E16 中上述性质成立，并通过 S1、S2 可达性检查排除“协议永不接受”的空模型。可达性查询的 false 表示接受事件能够发生，与安全查询成立的 true 具有不同含义。去掉窗口签名、角色绑定、账本核对、登记前验签的四个负对照分别破坏预期性质，说明这些检查在该模型中发挥作用。

模型没有覆盖预算数值、输入数值合法性、同源多摘要拒收、哈希链宿主重写、统计防御及性能。这些分别由代码检查、回归测试与算法论证支撑，不能用 Q1—Q5 代替。E34 在便携包内使用 ProVerif 2.05 重新求解主模型、可达性查询及四个负对照，结果符合登记预期；复验记录与原模型证据分别保留。

2.6.4 设计约束与实现验证

安全论证与实现检查采用不同证据。隐私性依赖固定参与集合和随机化机制；支持及影响界依赖来源身份与留一诚实多数；ProVerif 只讨论抽象协议事件。程序测试再检查模型未覆盖的数值输入、消息解析、重复来源、账本链和资源路径，避免用任一层的通过代替另一层保证。

当前实现对非法 ε 、非有限数值及结构错误返回可解释错误，拒绝无效登记；预测前先验证账本，链损坏时直接拒答。WebSocket 字段错误不会启动计算，并允许连接继续接收后续合法请求。静态资源限制在构建目录内。上述约束均有保留的回归用例，当前版本执行结果见 3.4.5。

历史缺陷、修复前失败现场及历次候选验证另存《工程验证与历史记录附件》。这些记录用于追溯检查如何形成；本报告不把历史电脑的通过记录继承为当前程序的异机验收，也不将软件测试数量视为算法安全强度。

2.7 前端设计与实现

五个页面围绕同一条使用路径组织：先理解交换架构，再运行预测，观察攻击影响，核对账本，最后查看统计证据。前端只显示后端返回的决策与已登记统计，不在

浏览器重算算法均值、区间或隐私预算。

全局数据集选择与各业务页面同步；加载中、空数据、失败和已完成结果分别呈现。长表与拓扑在局部区域滚动，窄窗口按顺序纵向排列；操作期间保留运行状态和可解释的错误信息，避免将旧请求结果归属于新参数。

2.7.1 总览与冷启动预测

总览先给出数据交换关系和三项防线，再提供“运行无攻击预测、带入攻击对照、核对账本、查看历史证据”的引导。预设填入数据集和参数后仍需用户点击运行，避免进入页面即产生账本记录。



图 2-5 总览与多源摘要可信交换架构

来源关系图说明发布端、网关、目标服务及登记核验的连接方式；原型在同一宿主进程模拟这些角色。总览还提供分步引导，选择预设只填入参数，运行需用户确认启动。

预测页校验数据集、目标、 ε 、发布长度、每源报告数及随机种子，并将同一已

完成请求的参数带入攻防页。结果同时显示真实榜单、三态原因、离线评价与审计编号。重放按钮沿用数值输入；JSON 导出保留请求快照、结果、程序源文件指纹和数据指纹，便于对照两次运行。



图 2-6 冷启动预测结果与检查结论

TRD 商圈 10；ε =2，m=40，每源 1,000 条，seed=1，无攻击。运行 run-86bfaeeee2、窗口 W001 输出 NORMAL，Recall=0.800、NDCG=0.9574。无防御方差加权在此单次运行得到相同离线指标；该图用于说明检查通过的完整流程，不支持无攻击精度优势。

日志向上阅读时停止自动跟随；界面显示后端真实事件的顺序回放，回放节奏不代表网络传输或分布式系统时延。结果绑定已完成响应，目标真值只用于离线评分，不进入摘要发布、网关准入或融合。单次预测截图用于说明功能与数据流，不纳入历史算法统计。

2.7.2 攻防实验室与账本审计

攻防页按发布端报告筛查、网关协议准入、整体融合三层呈现处理结果。攻击成功率同时列出入榜目标数和攻击目标总数，防止把 0、缺失或拒答混作防御成功。合法来源伪造数值可以通过签名核验，仍需观察摘要级防御及残余攻击。

用户可单次运行或顺序遍历十种攻击，逐行保留参数、种子与运行编号。中断后标明未完成项，不把已运行切片当作完整实验。界面导出来自已完成快照；历史结果、

单次演示和批量功能遍历均不混入已登记统计。

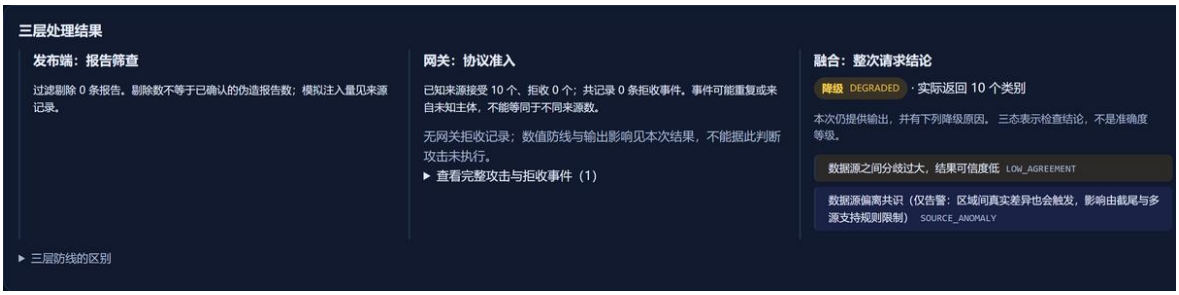


图 2-7(a) 发布端 网关与融合三层处理

TRD 商圈 3； ε =1，m=20，每源 5,000 条，seed=20260929；一名来源实施权重劫持；运行 run-cf85a32766、窗口 W003。10 份摘要通过准入，报告级筛查移除 0 条，最终 DEGRADED 并提示 LOW_AGREEMENT 和 SOURCE_ANOMALY。合法签名不能保证数值诚实，准入通过不表示没有攻击。单次演示注入 3 个目标；全部 11 个留一目标、5 个种子的 55 次统计见 3.4.1：PrivEdge 的 AS 为 0.218（95%区间 0.139 – 0.297），无防御方差加权为 1.000。



图 2-7(b) 同一次攻击的指标与分子分母

同一次 run-cf85a32766：无防御方差加权的 3 个攻击目标全部入榜（3/3），PrivEdge 为 1/3；Recall 分别为 0.400 与 0.600，NDCG 分别为 0.616 与 0.864。分子分母来自本次返回的目标集合及榜单，不由四舍五入的比例倒推。此单次演示不并入第三章五种子统计。

账本页突出完整性结论、当前条目数、注册密钥数及链头。逐来源预算图读取 latest_budget 的已用量与各自上限；空账本说明尚无业务记录，不能将空链校验解释为已有交易通过审计。审计详情保留拒收原因、请求编号、输入摘要和哈希。



图 2-8 账本副本篡改演练与拒答

W001 后的副本演练将第 0 条 ε 由 2 改为 0，检测首个断点并返回 REFUSED 及 LEDGER_CORRUPTED。原账本演练前后均为 20 条、链头一致、完整性通过。逐来源预算显示当前窗口，不表示跨窗口已累计同一用户的隐私消耗。

副本篡改演练只修改复制的账本，并显示修改项、断点和 REFUSED 及 LEDGER_CORRUPTED 原因。演练结束后重新读取原账本，比较条目数、链头和完整性；读取失败可独立重试。若并行业务使原快照变化，界面不宣称原账本与演练前逐字节不变。

2.7.3 实验中心与证据展示

实验中心按数据集、ε 和场景查看四方法的 Recall、NDCG、攻击成功率与拒答率，表格和图均读取后端规范摘要。它提供结果快照导出以及运行、种子、区间和原件指纹入口；不在浏览器重新生成随机报告或重算均值。



图 2-9 四方法历史对照与结果导出

TRD、 ε =2、无攻击，读取 E28 四方法描述性比较并显示均值、经验区间及导出入口。该截图展示既有证据，不是重新执行统计实验。

描述性、既有实验及文档三类资源分别加载和重试，单类数据缺失不隐藏其他资源。描述性证据核验失败时不显示已核验文案；零值、缺失值、缺失区间和基线拒答率不适用分别表达。完整运行编号、种子、样本量和文件指纹可展开核对。

四方法结果属于描述性比较。界面展示其冻结时序和种子复用限制，统计文件核验通过只表示读取产物与登记一致。单次演示、页面核对与工程回归均不会把描述性证据升级为确认性结论。

2.8 后端设计与实现

后端由 FastAPI 服务、DemoEngine、核心可信交换管线及登记证据读取模块构成。服务将请求解析为 RunRequest，按 dataset 选择引擎；演示引擎组织采样与攻击场景，并调用 Publisher.release 和 ColdStartService.predict。接口返回业务决策、审计摘要、事件和独立的离线评价。

2.8.1 服务接口与模块实现

接口	返回或操作	错误与来源
GET /api/datasets	数据集、源 ID、类别域和攻击选项。	未知数据集不使用猜测的源 ID。
POST /api/run	同步运行并返回 decision/events/audit/evaluation。	未知数据集 404；未知目标/攻击 400；字段校验 422。
WS /ws/run	kind=event 实时步骤，最终 kind=result 或 error。	解析错误给 error 且可继续；引擎异常也给 error。
GET /api/ledger/{dataset}	账本链状态、断点、条目、预算和注册表。	记录范围受展示限额约束。
POST /api/ledger/{dataset}/tamper-drill	修改副本并验证链损坏与预测拒答。	不修改原账本；空账本返回提示。
GET /api/audit/{dataset}	最近的审计记录。	是原型内记录，不是独立审计服务。
GET /api/evidence	utility/security/hijack/formal/overhead。	读取代码中 REGISTERED 指定的登记运行。
GET /api/evidence/a8	独立的 A8 登记状态、方法、结果及来源。	未运行或证据不合法时不返回统计数值。
GET /api/prereg	预注册及结果说明文本。	不是触发新统计实验的入口。

接口	返回或操作	错误与来源
GET /api/evidence/a8/descriptive	E28 描述性四方法、条件、区间、拒答率及来源。	损坏不显示数值；不升级历史预注册资格。
GET /api/version	版本与源文件身份	读取版本号、程序文件指纹及三套标准数据哈希，供导出记录绑定。

RunRequest 约束 ε 大于 0 且不超过 4，top_m 为 10 至 80，users 为 1000 至 20000，attackers 为 1 至 3，β 为 0 至 0.3。seed 用于可复现演示；负值由运行时校验产生明确错误。REST 与 WebSocket 调用同一引擎，但字段错误的表达分别是 HTTP 校验响应与 WebSocket 错误帧。

流式执行使用工作线程将事件投递给异步队列，主协程依序发送；当前连接逐次处理请求，正常请求以 result 终结，引擎异常以 error 终结。WebSocket 请求解析失败不会启动工作线程。该行为不表示已经实现任务取消、服务级超时、配额或连接鉴权。

版本接口按相对路径对 Python 源码、已构建前端、pyproject.toml 及 requirements.lock 计算文件指纹；数据哈希单列。它记录实际服务文件的身份，不覆盖程序包全部载荷，也不是签名或作者权利证明。导出请求版本失败时明确表示未取得身份，不能沿用无关旧值。

后端分别保留合法请求的数值重放、签名与准入事件、决策与离线评价；目标真值只用于评价。账本按当前窗口记录发布预算，演示运行会建立新窗口。跨窗口重复用户的组合预算需要参与管理，当前原型不能仅凭报告数自动确认用户集合不重叠。

2.8.2 运行流程与实现边界

描述性导出保留三组原 manifest/results/summary 和完整 review 字节，另存规范摘要，统一 simple_average→average、trimmed_frequency→robust_baseline。每次读取核对原始产物、复核产物、独立复算记录和导出摘要指纹，并核方法配对、种子、

目标×种子样本数及条件覆盖。导出时间不是实验时间，复核时方案快照不冒充预先冻结。

四方法离线工具 compare_v1 直接构造 AdmissionResult 并调用 decide，只比较统计方案，不经过真实签名、准入和预算登记。描述性结果通过独立入口接入；保留严格预注册绑定入口的空登记，不从历史结果补造预注册哈希。

演示引擎按数据集在进程中缓存，并使用同数据集运行锁保护共享状态。账本、源密钥和历史窗口摘要驻留内存，重启会重新建立状态。既有证据接口使用单进程缓存，更新后需要重新加载或重启；独立 A8 接口每次请求重新读取当前登记，不使用该缓存。

前端构建文件由后端同端口托管，修改源码后需要重新生成 dist。当前服务是本地演示原型，无登录和生产鉴权；部署使用的 TLS、持久化及独立审计没有作为已完成能力报告。静态文件路由限制在 dist 范围内，已关闭的越界问题由回归测试继续覆盖。

实验中心分别展示既有 E9/E10/E13/E16/E6 运行和 E28 描述性四方法结果。现场 run_id 只标识单次演示；描述性结果保留其冻结/种子限制，旧严格绑定入口无登记不代表没有描述性结果。数值与页面均从相同规范摘要读取，前端不重算均值或区间。

A8 登记表通过哈希绑定预注册与 manifest，适配器校验运行完成状态、数据集和种子一致性，并核对原始结果与 summary 输出哈希。同条件下要求各已完成方法的覆盖、种子和样本数一致；缺失指标为 null 并附原因，外部鲁棒方法不适配必须给书面说明。登记缺失、证据损坏和部分完成分别显示状态，不用零值掩盖缺口。文件完整性和格式检查不能代替实验方法或统计结论复核。

第三章 作品测试与分析

本章回答三个问题：防御相对简单平均及鲁棒适配基线有何收益和代价；支持与权重设计在什么条件下失效；协议和程序是否执行了设计规定的检查。统计结果来自既有登记运行及独立复算，当前程序验证单独报告。单次界面运行不并入五种子统计。

3.1 测试方案

3.1.1 系统功能与接口测试

功能测试覆盖总览、冷启动、攻防实验室、账本审计和实验中心五个页面，检查完整操作流程、三态输出、结果解释、异常提示及恢复能力。接口和核心测试覆盖三套数据与 11 种运行模式的组合、非法参数、WebSocket 错误处理、账本首条/中间/末条篡改及正常、降级、拒答状态。有效输入应完成对应流程；非法输入应返回可理解的客户端错误或应用错误消息；账本损坏应被发现并触发拒答。

表 3-1 系统测试层次与预期行为

测试层次	核查内容	预期行为
原有回归	原有核心与接口用例	已有功能保持通过
新增接口与核心验收	三数据集×11 模式、非法参数、三态与账本边界	合法输入完成；非法输入可解释；状态与拒绝原因一致
五页浏览器操作	结果展示、空状态、服务不可用、连接中断	数据与结果身份一致；失败后可恢复或重试
快速切换	切换数据集后立即调整目标、用户数并开始	请求中的数据集和目标属于同一数据集
证据核对	数据哈希、CSV 统计、跨版本记录、图表口径	数字可追溯到运行记录，比较口径一致

3.1.2 算法实验与对照设计

正文统计结果采用已有算法实验，经来源核验与独立统计复算保留。E34 另执行小规模离线重跑以检查复现入口，不代替原完整算法网格，也不并入下列统计。效用实验采用留一目标设计，每轮只用其他区域的摘要预测目标区域，再用目标真实频率离线评分。安全实验比较不同防御配置下的攻击影响，并保留不满足预注册判定的结果。

效用主网格为 ε∈{0.5,1,2,4}、发布长度 m∈{10,20,40}，评价 Top-10；源数量实验固定 m=20、ε∈{1,2}，比较 3、5 与全部源。安全主实验固定每源 5,000 条、m=20、ε∈{1,2}，覆盖伪造用户与 1/2 个被攻破发布者。D0 为团队原方差加权方法，D3 为发布端过滤及网关截尾、支持阈值 t=2，D4 在此基础上增加权重封顶 κ=2。当前默认 D4 与旧主线记录的对应关系由证据 E14、E19 的全字段比较验证。非隐私源平均作为参照方法；它使用源分布，不是目标任务准确率的数学上界。

本项目的攻击器对每份伪造报告抽取 256 个候选哈希种子，统计每个种子的各桶包含多少目标类别，选择目标类别同桶数最多的种子和桶值直接报告，再将伪造报告并入诚实报告。它是 MGA 风格的有界随机搜索，面向目标集合而非单一指定项，也不保证报告支持全部目标。搜索预算、目标项处理和哈希实现由本项目代码确定，因而不具有全局最优保证，也不是论文代码的逐行复现。实验中的 β 定义为伪造报告数与诚实报告数之比；若改写成总报告占比，应使用 β/(1+β)。

四方法比较把简单平均、无防御方差加权、缺失补零的坐标截尾适配和 PrivEdge 置于相同数据与攻击条件下。前三种方法共享未筛查摘要；PrivEdge 包含发布端筛查与摘要级防御，是整套统计方案比较。对照的完整配置与解释边界见 3.4.1。

UTILITY_V1 和 SECURITY_V2 使用种子 101、211、307、401、503；SECURITY_V4 改用 601、709、811、907、1009。后者是在同一数据集、同一攻击族上使用新种子的确认性复验，不能视为新增独立数据集验证。四方法原始运行与复核记录登记为 E28，3.4.1 报告描述性切片和限制；不称为新种子独立确认性复验。

3.1.3 程序验收与复现范围

程序验收检查解压完整性、服务启动、五页交互、错误恢复及自动回归。当前程序从新解压目录启动，运行时、依赖和源码路径均须位于程序包内。该检查证明本机

解压运行的可行性；最终冻结程序仍需第二台实体电脑验收。历史 B 候选的 macOS 与 Windows 记录保存在工程附件，不能自动转移为新版本结论。

3.2 测试环境

既有算法运行的 manifest 记录 Windows 11（10.0.26200）、Python 3.12.14 与 NumPy 2.3.5。原执行者报告处理器为 AMD Ryzen 7 9800X3D、内存 32 GB；manifest 未独立验证物理型号与容量。当前 E34 在本机 Windows x64 的新解压目录验收，使用随包隔离 Python、锁定依赖和 ProVerif 2.05，不调用已安装的 Python 或 Node.js；这一检查仍属于同机验证。

表 3-2 统计与当前程序验证环境

验证对象	环境与范围	结论边界
登记算法运行	Windows 11；Python 3.12.14；NumPy 2.3.5。数据、种子、代码指纹由运行 manifest 记录。	对应既有数据与攻击网格;本次复算不重新生成报告。
当前整合程序	本机 Windows x64；隔离 CPython 及锁定依赖；现成前端由本地服务托管。	同机新解压与自动检查；不代表所有设备兼容或真实分布式部署。

3.3 数据集与评价标准

三套数据分别承担主场景、跨域对照与异质性压力测试。本节将数据规模、预处理边界和评价口径分开说明，数据来源及许可记录见附录 D。

3.3.1 数据集与预处理

表 3-3 三套标准数据规模

数据集	用途	目标区域数 / 每轮全部源数	定义域类别数 / 标准表观察类别数	标准记录数
美团 TRD	外卖首单代理任务，主场景	11 / 10	122 / 106	183,346
Olist	巴西电商跨域对照	6 / 5	71 / 70	62,491
Massive-STEPS	城市签到异质性压力测试	7 / 6	156 / 147	62,053

定义域类别数依据 domain.json，观察类别数依据本包 private_events.csv.gz 去重，两者不应混写。本实验采用完整定义域。每次留出一个目标区域，只读取其他区域的统计摘要进行预测；目标真实频率仅用于离线评分。标准表仅含区域与类别列，本次核验不据此重新证明原始用户去重过程。TRD 的首单规则与 Olist、Massive 的预处理来源须结合原审计及数据许可说明理解。

每源抽样 5,000 条标准记录，三套数据的全部源均满足这一数量。目标数分别为 11、6、7，每个固定条件对应 55、30、35 次“目标×种子”运行。

3.3.2 指标与统计方法

• Recall@10 为预测与目标真实 Top-10 的交集比例；NDCG@10 按目标真实频率评价排序。

• AS 为 3 个攻击目标类别进入预测 Top-10 的比例，范围为 0 至 1，不等同于“每次请求是否至少命中一个”的二元成功率。

• 先在同一目标内对 5 个种子取均值，再对目标等权平均。方法差异以同一目标配对，使用 NumPy seed=0、2,000 次目标级有放回抽样得到 95%区间。目标数仅 6 至 11 且

留一实验共享源，区间描述当前目标集合的重采样不确定性，不代表任意城市总体的独立随机抽样推断。

• 效用实验中 REFUSED 请求按 Recall=NDCG=0 纳入总体指标，同时另报拒答率。只看已回答请求会产生选择偏差。

• 候选覆盖上界基于原始摘要候选并集，不能当作经过支持筛选后的实际准确率。

3.4 结果展示与分析

3.4.1 四方法描述性对照

四方法比较采用简单平均、无防御方差加权、本地适配的坐标截尾均值和 PrivEdge。三组原始运行登记为 E28：每源 5000 条诚实报告、Top-m=20、Top-k=10、 ε ∈{1,2}、9 场景、5 种子和全部留一目标，共 8640 行、216 个方法单元。TRD、Olist、Massive 分别有 11、6、7 个目标，每次使用其余 10、5、6 个来源。攻击目标类别数为 3，与留一目标区域数不同。

预注册冻结无法独立确认：原 manifest 未保存方案内容哈希，复核时快照不能证明运行前冻结；101、211、307、401、503 曾用于旧实验，不能称为未使用新种子的独立确认。因此以下结果作为描述性比较，不沿用旧 review 的确认性通过标记，不回填历史 manifest。

以下先比较无攻击代价，再比较同一 ε 下的双源权重劫持。完整两档 ε 、九场景共 216 个方法单元保存在描述性证据入口，未展示切片不视为缺失。表内 95%经验区间先在目标内平均五个种子，再对目标作 2,000 次 bootstrap；目标共享来源，未作多重比较校正。

表 3-4 无攻击对照　ε=2　均值与目标级 95%经验区间

数据	方法	NDCG@10	Recall@10
TRD	简单平均	0.9614 [0.9505, 0.9722]	0.8145 [0.7764, 0.8473]
TRD	无防御方差加权	0.9614 [0.9505, 0.9722]	0.8145 [0.7764, 0.8473]

数据	方法	NDCG@10	Recall@10
TRD	坐标截尾（适配）	0.9618 [0.9504, 0.9726]	0.8109 [0.7745, 0.8418]
TRD	PrivEdge	0.9613 [0.9500, 0.9724]	0.8127 [0.7745, 0.8455]
Olist	简单平均	0.9598 [0.9494, 0.9691]	0.8033 [0.7767, 0.8300]
Olist	无防御方差加权	0.9599 [0.9497, 0.9692]	0.8033 [0.7767, 0.8300]
Olist	坐标截尾（适配）	0.9569 [0.9473, 0.9668]	0.7933 [0.7633, 0.8200]
Olist	PrivEdge	0.9599 [0.9497, 0.9692]	0.8033 [0.7767, 0.8300]
Massive	简单平均	0.7787 [0.7464, 0.8106]	0.6600 [0.6257, 0.6943]
Massive	无防御方差加权	0.7763 [0.7451, 0.8075]	0.6571 [0.6171, 0.6943]
Massive	坐标截尾（适配）	0.7599 [0.7132, 0.8030]	0.6629 [0.6143, 0.7058]
Massive	PrivEdge	0.7799 [0.7380, 0.8198]	0.6571 [0.6171, 0.6943]

无攻击结果不支持 PrivEdge 全面优于简单平均的主张。三种基线共享未筛查摘要，PrivEdge 额外进行发布端筛查及摘要级防御，因此这是整套统计方案比较，不是只更换一个聚合公式的消融。坐标截尾基线采用 Top-m 缺失补零、trim=1 的本地适配，不继承梯度聚合论文的误差界。

表 3-5 双源权重劫持对照　ε=2　均值与目标级 95%经验区间

数据	方法	NDCG@10	攻击成功率
TRD	简单平均	0.9449 [0.9328, 0.9561]	0.2061 [0.1394, 0.2667]
TRD	无防御方差加权	0.7102 [0.6880, 0.7322]	1.0000 [1.0000, 1.0000]
TRD	坐标截尾（适配）	0.9608 [0.9499, 0.9710]	0.0182 [0.0000, 0.0364]
TRD	PrivEdge	0.9596 [0.9483, 0.9699]	0.0606 [0.0303, 0.0970]
Olist	简单平均	0.8889 [0.8640, 0.9125]	0.6889 [0.6000, 0.7778]
Olist	无防御方差加权	0.6390 [0.6057, 0.6692]	1.0000 [1.0000, 1.0000]
Olist	坐标截尾（适配）	0.9378 [0.9238, 0.9507]	0.1667 [0.0889, 0.2222]
Olist	PrivEdge	0.9385 [0.9236, 0.9506]	0.1889 [0.1444, 0.2556]
Massive	简单平均	0.7189 [0.6857, 0.7519]	1.0000 [1.0000, 1.0000]
Massive	无防御方差加权	0.4581 [0.4337, 0.4860]	1.0000 [1.0000, 1.0000]
Massive	坐标截尾（适配）	0.7146 [0.6609, 0.7643]	1.0000 [1.0000, 1.0000]

数据	方法	NDCG@10	攻击成功率
Massive	PrivEdge	0.7377 [0.6916, 0.7866]	0.8476 [0.7905, 0.9048]

Massive 双源权重劫持下 PrivEdge 攻击成功率仍约 0.8476；即使排序质量或相对基线有所改善，也不能写成合谋目标已被消除。现有网格中 PrivEdge 拒答率为 0；无拒答不表示预测准确，三种裸基线未实现三态决策，其拒答率标为不适用。β 是伪造报告数/诚实报告数，不能直接称总报告占比。

该切片也显示鲁棒适配基线更优的情况。TRD 中坐标截尾的 AS 为 0.0182，低于 PrivEdge 的 0.0606，NDCG 为 0.9608 与 0.9596；Olist 中 AS 为 0.1667 与 0.1889，PrivEdge 的 NDCG 仅略高（0.9385 对 0.9378）。因此不能把“防御组件更多”解释成统计指标全面领先。

这些结果支持的结论是：无防御方差加权易受低方差伪报影响，截尾和封顶可以降低部分影响，但支持门槛无法消除达到门槛的合谋。PrivEdge 同时实现摘要准入、预算登记和原因输出，属于另一组工程能力；协议能力不能作为统计指标落后的抵销项。该对照直接调用统计决策入口，未执行真实签名或账本登记，协议效果另见 3.4.4。

3.4.2 分层防线与权重封顶

本节进一步区分防御组件。原方差加权（D0）与发布端筛查＋网关截尾及支持门槛（D3）用于观察两层防线；在 D3 之上增加权重封顶的配置记为 D4。下文的配置名只用于对应原运行记录，不代表不同产品版本。

下表固定 ε=1、m=20，列出 AS 从 D0 到 D3 的变化，每个条件使用 5 个种子及全部留一目标；ε=2 的完整表与配对区间保存在附录 B 的证据 E9 及本次安全结果复算记录。

表 3-6 攻击成功率由 D0 到 D3 的变化（E9， ε=1，m=20）

场景	TRD	Olist	Massive-STEPS
1 源伪造 2%	0.0303 → 0.0303	0.0667 → 0.0556	0.1048 → 0.1048
1 源伪造 5%	0.2606 → 0.0000	0.3889 → 0.0000	0.5905 → 0.0190
1 源伪造 10%	0.9030 → 0.0000	0.9778 → 0.0000	1.0000 → 0.0190

场景	TRD	Olist	Massive-STEPS
2 源各伪造 5%	0.9030 → 0.0000	0.9778 → 0.0000	1.0000 → 0.0190
1 个被攻破发布者	0.0909 → 0.0606	0.1333 → 0.0778	0.6857 → 0.2190
2 个被攻破发布者	0.4727 → 0.3697	0.9000 → 0.5667	1.0000 → 0.9810

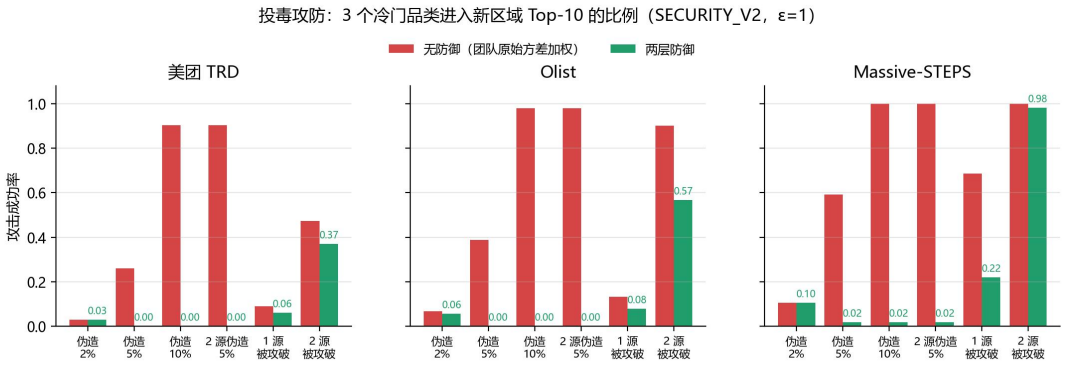
三套数据的预注册“全部攻击单元显著降低 AS”均未完全满足：Massive 9/12、Olist 8/12、TRD 8/12。以基线 AS≥0.1 筛出的 26 个单元中 24 个差值区间上界低于 0，是结果后分层描述，不应替代预注册判定。所测伪造比例≥5%的 MGA 场景中，防御后 AS 最高 0.0190；这一结论限定为现有攻击生成器、数据及参数。弱攻击和两源合谋保留明显残余风险。

权重劫持与确认性复验

SECURITY_V3 未满足原采用规则，因此保留为探索性证据。随后 SECURITY_V4 换用 5 个新种子，检验由 V3 提出的“在现有场景不回退、恢复单源劫持下排序质量”假设。三套数据各 14/14 个场景×ε单元满足均值不回退约束，各 4/4 个单源劫持/降级单元的 NDCG 配对区间下界高于 0。单源场景中 D4 相对 D3 的 NDCG 提升范围为 0.0337 至 0.6505；D4 与无攻击 D3 的平均 NDCG 差绝对值小于 0.09。由于复用原数据与攻击族，新种子结果不能证明对未见数据分布和任意自适应攻击的泛化。

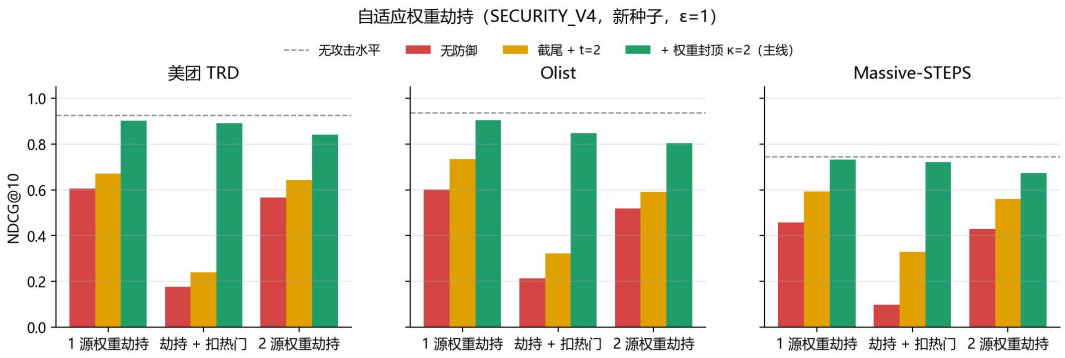
t=2 的支持保证只覆盖 f<2 且注入类别未被任何诚实源发布的情形；它不保证已有类别排序不受影响。当 f=2 时，ε=1 的两源权重劫持 AS 仍可达到 0.93 至 1.00，权重封顶主要保护排序效用。

Windows 功能巡检还保留一个单次失效示例：Olist 的 RJ@W2018 目标，在 ε=1、m=20、每源请求 2,000、种子 20260929 下，权重劫持及“权重劫持＋扣下真实热门”两项 PrivEdge 的 AS 均为 1.00，NDCG 分别为 0.805、0.681。该记录表明排序效用改善与攻击目标完全消除是不同目标；不能因巡检执行通过或输出 NORMAL 就写成所有攻击已被防御。这是单一目标和种子的功能样例，不并入上文每源 5,000、5 种子的统计结果，也不外推为所有条件下的失败（B-W1）。



数据来源：runs/.../security_v2_meituan_trd-20260929T031030Z-fd18bc；security_v2_olist_brazil-20260929T031029Z-1ed46e；security_v2_massive_steps-20260929T031029Z-1bd2f5

图 3-1 六类攻击场景的 AS（E9， ε =1）



数据来源：runs/.../security_v4_meituan_trd-20260929T145355Z-8514ad；security_v4_olist_brazil-20260929T145354Z-3c22fd；security_v4_massive_steps-20260929T145354Z-705ea4

图 3-2 权重劫持的新种子复验（E13， ε =1）

3.4.3 隐私效用与参数敏感性

本节 UTILITY_V1 与 3.4.1 的 COMPARE_V1 是不同运行器。二者都把 ε 在各自参数网格中的索引写入随机种子序列，但网格分别为[0.5,1,2,4]与[1,2]；因此相同基础种子及相同 ε 不表示同一扰动实例。表 3-7 的 TRD、ε =2、m=20 的 Recall 为 0.8345，表 3-4 中 PrivEdge 为 0.8127，各自对应原运行，不能跨运行器逐值合并或当作同次结果冲突。

下表取 m=20、全部源，均为目标级均值。每行 5 个种子；TRD、Olist、Massive 分别有 11、6、7 个目标。

表 3-7 隐私与效用结果（E10、E14，m=20，全部源）

数据集	ε	非隐私 Recall	方差加权 Recall	PrivEdge Recall	PrivEdge NDCG
美团 TRD	0.5	0.8727	0.4873	0.4873	0.7704
美团 TRD	1	0.8727	0.7600	0.7600	0.9356
美团 TRD	2	0.8727	0.8345	0.8345	0.9655
美团 TRD	4	0.8727	0.8582	0.8582	0.9707
Olist	0.5	0.7833	0.6133	0.6133	0.7874
Olist	1	0.7833	0.7967	0.7967	0.9429
Olist	2	0.7833	0.7867	0.7867	0.9605
Olist	4	0.7833	0.7900	0.7833	0.9623
Massive-STEPS	0.5	0.6714	0.5086	0.5114	0.6742
Massive-STEPS	1	0.6714	0.5657	0.5657	0.7278
Massive-STEPS	2	0.6714	0.6600	0.6571	0.7789
Massive-STEPS	4	0.6714	0.6629	0.6657	0.7835

TRD 在 ε=2 时 Recall@10 为 0.8345，非隐私参照为 0.8727；NDCG@10 为 0.9655。预注册 U1 将“接近参照”具体定义为 Recall 差的区间下界不低于-0.10：在所测 ε=2 和 4 时三套数据均满足；ε=1 时只有 Olist 满足，Massive 与 TRD 未满足。U2 要求相对原方差加权的 NDCG 差区间下界不低于-0.02，Massive ε=4 的区间为 [-0.0345,0.0611]，未满足，其余所测 ε ≥1 条件满足。不能将“未检出损失”改写为所有条件均无代价。

E14 的 1,920 行 PrivEdge 结果与原效用运行全字段一致，因而上述数字亦适用于登记的封顶配置。该比较没有覆盖任意新增数据或参数。

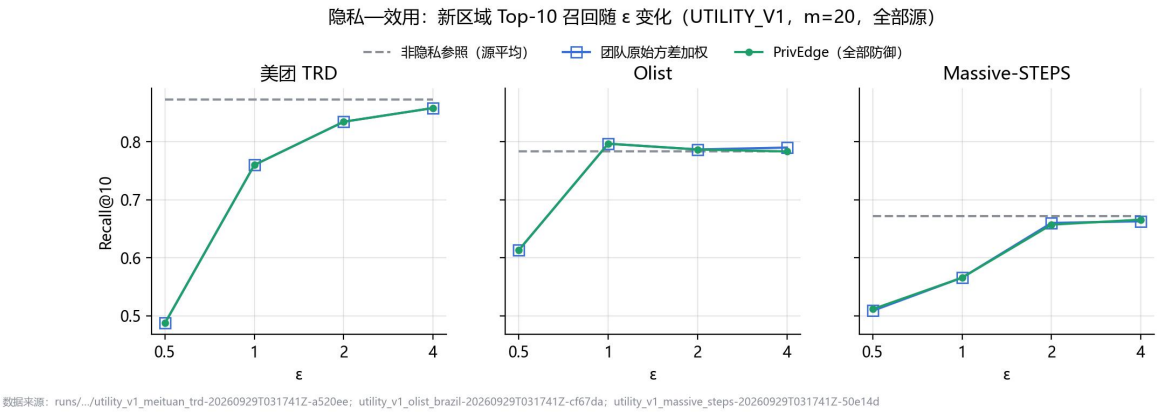


图 3-3 隐私与效用曲线（E10、E14，m=20，全部源）

表 3-8 发布长度与源数量敏感性（E10， ε =1）

数据集与条件	比较项	Recall@10（按顺序）	拒答情况
美团 TRD， ε =1，全部源	m=10/20/40	0.7255 / 0.7600 / 0.7800	0.0% / 0.0% / 0.0%
美团 TRD，ε =1，m=20	3/5/全部源	0.5000 / 0.6691 / 0.7600	10.9% / 0.0% / 0.0%
Massive-STEPS，ε =1，全部源	m=10/20/40	0.4743 / 0.5657 / 0.6029	20.0% / 0.0% / 0.0%
Massive-STEPS，ε =1，m=20	3/5/全部源	0.3771 / 0.5657 / 0.5657	22.9% / 0.0% / 0.0%

增大 m 可扩大候选覆盖，增加来源在这批数据中总体改善效用；两者都不能保证单次预测更准确。m=40 是原型的工程默认，主要依据当前数据中的覆盖与拒答权衡，开销实验则使用 m=20，不能直接把其摘要字节数作为 m=40 的实测结果。

三态反映输入接纳、来源数量与一致性检查。TRD 在 ε =0.5、m=40、全部源时，55 次输出全部为 NORMAL，但 Recall 仅 0.5345，低于非隐私参照 0.8727。因此 NORMAL 不构成预测质量保证；LOW_AGREEMENT 阈值 0.2 未经独立校准，不宜声称状态与真实准确度已被严格校准。

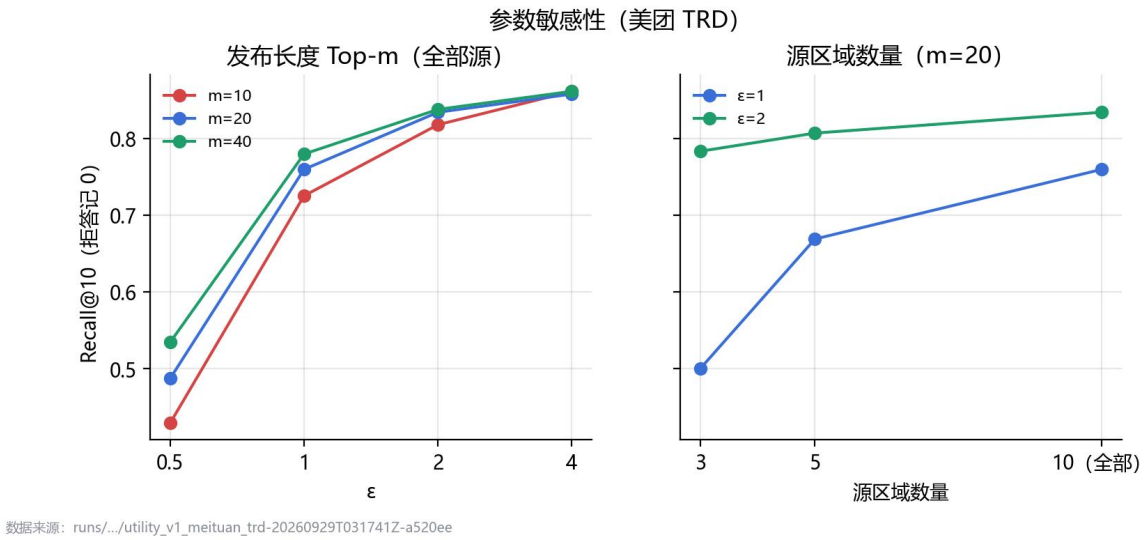


图 3-4 TRD 参数敏感性（E10，拒答计 0）

3.4.4 协议异常路径与模型验证

签名与账本验证针对消息在交换过程中的身份、内容和使用条件。它不识别已签名数值是否诚实，因此与 3.4.1、3.4.2 的统计攻击实验分开验收。下表列出关键异常及预期处置。

表 3-9 协议异常与实现处置

异常输入	预期行为	证据与解释
未注册密钥、错误角色或签名	登记或准入拒绝	注册表与签名回归；不接受冒名登记。
旧窗口、类别域不一致	拒收对应摘要	窗口与域检查；仍允许复用有效窗口摘要。
登记摘要与使用内容不一致	拒收对应摘要	摘要 digest 绑定；合法密钥也不能绕过该一致性检查。
预算超限或非法 ε	拒绝登记或输入	数值回归；不同窗口重复用户仍属部署假设。
账本副本首、中、末条损坏	REFUSED 并给出链损坏原因	预测前完整性检查；副本演练不破坏原账本。

异常输入	预期行为	证据与解释
同源多份有效摘要	拒收该源全部摘要	剩余来源是否足够由决策层判断，不必然整次拒答。

随包 ProVerif 2.05 重跑主模型的 Q1—Q5、S1/S2 可达性与四个负对照，结果符合预期。删除窗口签名、角色绑定、账本核对或登记前验签后，对应性质受破坏，说明查询并非仅因协议永不接受而成立。模型事件和假设见 2.6.3；预算数值、哈希链宿主重写与统计防御仍不由该符号模型覆盖。

3.4.5 当前程序验证

E34 开发目录 239 项 Python 测试通过;便携包在新解压目录执行相同 239 项并通过。前端 104 项自动检查通过。真实浏览器另完成 17 组检查，包括引导预设、种子校验与重放、参数携带、三层攻击解释、账本副本拒答、证据显示、数据集切换隔离、遍历中断及实际 JSON 下载。17 组不是 104 次浏览器测试；真实浏览器下载核查限于无攻击结果导出，其余导出类型由自动检查覆盖。

后端独立核对中，三套标准数据的固定合法请求 decision 及 evaluation 与 E33 一致；无攻击、权重劫持和篡改请求在固定种子下数值重放一致。十种攻击均完成运行，账本副本损坏返回 REFUSED 及 LEDGER_CORRUPTED，原账本不变；三个历史证据接口保持原结果。已有 23 份预注册文本保留不变，新复现方案单列。

便携包 6,064 项登记载荷核对一致，442 项应用源文件与主体一致，303 项受保护原件未变；运行时与依赖确认从包内加载。快速核心复现从每套数据取首个目标与 seed=101，覆盖两档 ε 、九场景和四方法，共 216 行；独立复核通过。此检查验证小网格能够执行，不是完整 8,640 行重跑或新增统计结论。形式模型重跑与历史图表重绘另保存新产物，不覆盖原证据。

测试组之间存在重复覆盖，分别报告而不相加为独立样本。极小正 ε 边界保留 3 条数值警告，对应用例返回可解释拒答。以上自动检查和本机页面验证不代替最终版本的实体异机验收，也不将文件一致解释为原创权利已确认。

3.4.6 完整应用流程

程序首页“正常交换”入口带入固定示例：TRD 商圈 10、ε=2、m=40、每源 1,000 条、seed=1，运行无攻击预测得到 NORMAL；原 TRD 商圈 3、 ε=1、m=20、每源 5,000 条、seed=20260929 仍可手动运行，得到 DEGRADED 并保留 LOW_AGREEMENT 原因；结果可导出，相同参数可带入攻防页。

一名来源权重劫持时，无防御方差加权的攻击目标入榜比例为 3/3，PrivEdge 为 1/3，结果仍为 DEGRADED。随后账本副本演练检测到损坏并拒答，重新核对原账本 20 条及链头不变；最后在实验中心查看独立的 E28 历史统计。该流程展示可追溯交换和失败解释，单次攻击收益不扩展成总体优势。

该流程把配置、真实运行、结果解释和来源证据连在一起。第二章五个页面的界面图绑定各自参数及运行记录，仅说明功能能够按所示路径执行。攻击示例即使输出检查通过，也可能有攻击目标进入榜单；用户需同时阅读状态、离线评价和攻击指标。当前验证支持本地演示，不代表真实经营收益。

3.4.7 旧管线通信与计算开销

开销记录采用合成 Zipf 数据、 ε=1、m=20、6 个源，常规耗时重复 5 次、验签至少 50 次，并记录中位耗时，原始 CSV 仅存汇总值，故本次不能重算重复间方差或置信区间。原运行还包含上下文信封，属于旧管线基准，不能作为当前 v2 全部实现的最新性能测试。

表 3-10 已登记通信与计算开销（E6， ε=1，m=20）

指标	存档结果	解释与边界
用户扰动	1.192—1.267 μs/用户	单机批量向量化，不是手机实测
发布端总耗时	5,000 用户/71 类 21.71 ms； 100,000 用户/500 类 1,393.57 ms	包含过滤；不含公网传输
峰值内存	最大 110.2 MB	仅所测合成网格
原始报告体积	100,000 用户时 1,200,000 B	CSV 所计二进制报告载荷

指标	存档结果	解释与边界
签名摘要信封	2,291—2,323 B，约 2.3 kB	固定 m=20；不含另计上下文信封
验签	0.098—0.101 ms	同机微基准
6 源网关预测	7.90—8.90 ms	原基准账本 12 条；不是大账本或并发容量证明

摘要体积在固定发布长度下基本不随用户数增长，支持“从逐用户报告转为固定长度摘要传输”的可行性。不能把该微基准外推为百万并发、移动端时延或持续增长账本的性能保证。

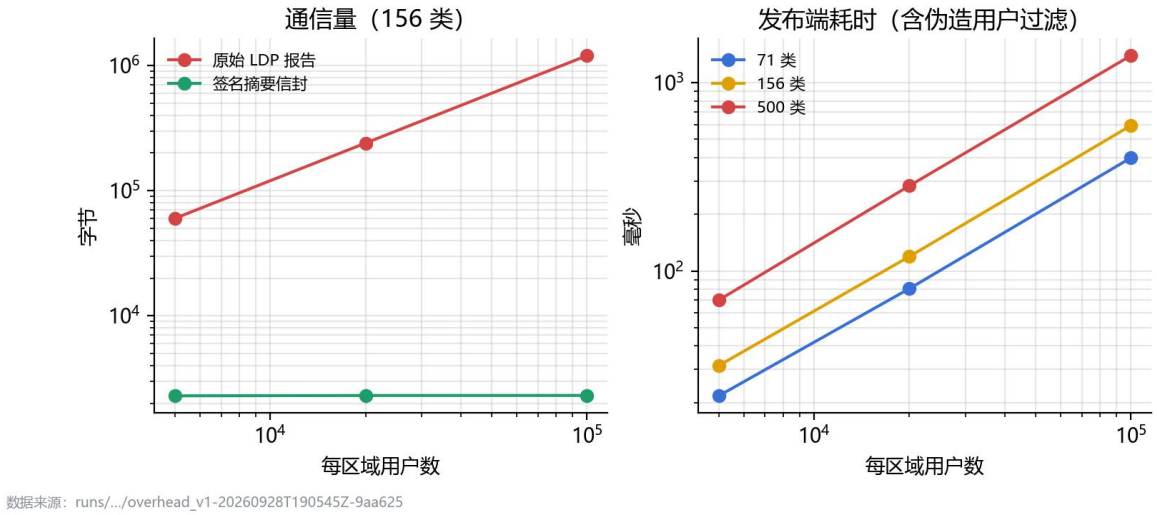


图 3-5 已登记通信与开销（E6，m=20，旧管线微基准）

第四章 创新性说明

4.1 按可见信息分层的两层抗投毒

本作品的系统设计起点是两种攻击入口掌握的信息不同。发布端可访问用户级OLH报告，网关只接收每个来源的Top-m摘要。将同一检测器直接搬到网关既没有所需报告，也无法防止持合法密钥的发布者自行编造摘要。PrivEdge据此把报告级筛查与摘要级约束放在不同信任边界。

发布端用共同支持异常筛除疑似伪造报告并重新估计；网关组合多源支持、留一截尾和权重封顶，处理绕过发布端的摘要作恶。两层通过带来源、窗口和预算的摘要接口连接。新增之处在于这一面向稀疏LDP摘要的信息分工和完整实现，不是重新提出OLH、MGA、坐标截尾或相关论文检测器。

证据闭环由3.4.2的报告攻击与来源攻击实验构成：所测TRD单源10%伪造场景中AS从0.9030降至0，权重劫持复验说明只约束频率仍需约束权重。该结论限定于现有攻击族和参数；四方法对照中已有鲁棒适配基线在部分切片更优，不能写成对所有已有方案的优势。

4.2 多源支持与数值影响约束

稀疏Top-m摘要既包含数值，也包含“哪些来源愿意发布此项”的支持信息。PrivEdge在截尾前统计原始支持，避免后续数值处理被误作来源支持；同时对频率和方差形成的权重分别约束。这样把候选能否进入与进入后影响多大分开分析。

定理1给出t-f个诚实支持的组合界；定理2在留一集合仍有诚实严格多数、无上下文路径及正有限权重等条件下，给出当前融合分数相对其诚实分量的上界。证明完整列于附录A，接口检查负责落实不同来源、有限数值和非空摘要等可检查条件。

两类结论均有明确边界。支持门槛不固定已有类别名次；影响界中的诚实分量仍由当前受攻击输入定义，不是无攻击反事实输出。n=10、f=1、 κ =2且诚实源权重相等(W=w)时，恶意权重份额上界为2/11≈0.1818。3.4.1保留Massive双源AS约0.8476以及Olist五源双攻击不满足定理2条件的结果，使理论保证与经验观察相互区分。

4.3 签名登记与使用绑定及可解释失败

仅对摘要签名只能证明密钥来源，无法回答摘要是否按预算登记、是否属于允许窗口，以及预测实际使用的内容是否与登记内容相同。PrivEdge 把主体角色、窗口、类别域与摘要内容放入签名和登记核对链，在目标服务预测前检查账本完整性，再把准入结果交给统计决策。

该设计将错误变成可追溯的业务结果：不合格摘要被拒收并记录原因，剩余来源不足或链损坏时拒答，能够继续使用的结果同时保留告警。页面将三态、离线效用和审计分区，避免把安全流程通过混同于预测准确。2.6.3 的符号正负对照、3.4.4 的异常路径和 3.4.5 的当前程序验证分别支撑逻辑与实现。

贡献限于原型内可核对的交换流程。内存账本尚无独立见证、防日志分叉与持久化恢复；具备合法权限的宿主重写整条链不在其保证内。四方法统计工具绕过真实协议，不以其输出替代本节的协议验证。

第五章 总结

5.1 已完成能力

PrivEdge 已形成从用户本地扰动、发布端筛查、摘要签名登记，到网关准入、抗投毒融合和结果解释的可运行原型。三套标准数据、五个页面、后端服务及登记实验在同一程序中连通，实验中心可以从报告结论追溯到条件、方法、种子和原始产物。

现有证据支持有限场景中的防御效果与工程可行性，而不支持无攻击普遍提精度或阻止全部合谋的主张。四方法对照将无攻击代价、鲁棒基线较优切片和双源残余攻击同时列出；支持与影响定理只在明确条件下成立。作品将这些边界作为结果解释的一部分，检查通过始终只表示流程条件达标。

5.2 技术局限与后续研究

统计方面，发布端联合支持阈值尚未作独立校准，Top-m 缺失、来源异质性和自适应攻击仍会影响防御。当前 bootstrap 区间反映有限目标集合，不能外推为任意地区的总体保证。后续应使用独立时间窗口与新攻击策略，同时比较效用、误报、漏报和拒答代价。

工程方面，角色仍在同一宿主进程模拟，内存账本与密钥重启后重建；生产使用需要持久化、访问控制、密钥治理和独立审计。跨来源、跨窗口是否重复包含同一用户无法由当前报告条数识别，隐私预算归属需要真实参与管理。

复现方面，本包的起点是随包标准表，完整原始下载与预处理依赖链尚未独立重建。最终冻结版本仍需实体第二电脑验收；成员权利、贡献和正式声明须本人确认。以上未完成事项在附录中明确标识，不由既有测试通过或文件哈希一致替代。

新区域选品展示了不直接交换个人原始记录时的协作方式。后续业务试点应在明确的数据使用条件下另行评价地域差异、选品收益与部署成本，当前排序代理实验不承担这些业务结论。

参考文献

[1] Tianhao Wang, Jeremiah Blocki, Ninghui Li, Somesh Jha. “Locally Differentially Private Protocols for Frequency Estimation.” Proceedings of the 26th USENIX Security Symposium (USENIX Security 17), 2017, pp. 729–745. https://www.usenix.org/system/files/conference/usenixsecurity17/sec17-wang-tianhao.pdf

[2] Úlfar Erlingsson, Vasyl Pihur, Aleksandra Korolova. “RAPPOR: Randomized Aggregatable Privacy-Preserving Ordinal Response.” Proceedings of the 2014 ACM SIGSAC Conference on Computer and Communications Security, 2014, pp. 1054–1067. https://doi.org/10.1145/2660267.2660348

[3] Raef Bassily, Adam Smith. “Local, Private, Efficient Protocols for Succinct Histograms.” Proceedings of the 47th Annual ACM Symposium on Theory of Computing (STOC 2015), 2015, pp. 127–135. https://doi.org/10.1145/2746539.2746632

[4] Xiaoyu Cao, Jinyuan Jia, Neil Zhenqiang Gong. “Data Poisoning Attacks to Local Differential Privacy Protocols.” Proceedings of the 30th USENIX Security Symposium (USENIX Security 21), 2021, pp. 947–964. https://www.usenix.org/system/files/sec21-cao-xiaoyu.pdf

[5] Xiaolin Li, Ninghui Li, Boyang Wang, Wenhai Sun. “Mitigating Data Poisoning Attacks to Local Differential Privacy.” Proceedings of the 2025 ACM SIGSAC Conference on Computer and Communications Security (ACM CCS 2025), 2025, pp. 1230–1244. https://doi.org/10.1145/3719027.3744839 预印本：https://arxiv.org/abs/2506.02156。

[6] Dong Yin, Yudong Chen, Kannan Ramchandran, Peter Bartlett. “Byzantine-Robust Distributed Learning: Towards Optimal Statistical Rates.” Proceedings of the 35th International Conference on Machine

Learning, PMLR 80, 2018, pp. 5650–5659.
https://proceedings.mlr.press/v80/yin18a.html

[7] Peva Blanchard, El Mahdi El Mhamdi, Rachid Guerraoui, Julien Stainer. “Machine Learning with Adversaries: Byzantine Tolerant Gradient Descent.” Advances in Neural Information Processing Systems 30 (NIPS 2017), Curran Associates, Inc., 2017, pp. 119–129.
https://proceedings.neurips.cc/paper_files/paper/2017/file/f4b9ec30ad9f68f89b29639786cb62ef-Paper.pdf

[8] Cynthia Dwork, Aaron Roth. The Algorithmic Foundations of Differential Privacy. Foundations and Trends in Theoretical Computer Science 9(3–4), 2014, pp. 211–407. https://doi.org/10.1561/0400000042

[9] B. Blanchet. Modeling and Verifying Security Protocols with the Applied Pi Calculus and ProVerif. Foundations and Trends in Privacy and Security, 1(1–2):1–219, 2016. 工具与说明：
https://bblanche.gitlabpages.inria.fr/proverif/

[10] B. Laurie, A. Langley, E. Kasper. Certificate Transparency. RFC 6962, 2013. 本稿引用历史设计，不把它作为当前部署规范：
https://www.rfc-editor.org/info/rfc6962/

[11] J. Josefsson, I. Liusvaara. Edwards-Curve Digital Signature Algorithm (EdDSA). RFC 8032, 2017. https://www.rfc-editor.org/rfc/rfc8032

[12] R. Bassily, K. Nissim, U. Stemmer, A. Thakurta. Practical Locally Private Heavy Hitters. Advances in Neural Information Processing Systems 30 (NIPS 2017), 2017.
https://proceedings.neurips.cc/paper_files/paper/2017/hash/3d779cae2d46cf6a8a99a35ba4167977-Abstract.html

附录 A 完整证明与条件核对

A.1 符号和实现对应。设 H 为诚实来源集合，|H|=n−f；$v_{s,i}$表示来源 s 对品类 i 的稠密诊断值，$z_{s,i}$表示实际融合输入，未发布项在最终融合中取 0；u_s为未封顶的不确定度权重，ω_s为封顶后的实际权重。以下证明只讨论来源已经通过准入、每个来源保留一份摘要且 context=None 的路径。

A.2 隐私引理。固定一个与输入无关的随机种子 a。若H_a(x)=H_a(x′)，则随机响应输出分布相同；若两者不碰撞，对 y=H_a(x)有 P(y|x)=p、P(y|x′)=r，对其他桶至多交换 p 与 r 或保持相同。由于 p/r=e^{ε}，任意输出桶的条件概率比不超过e^{ε}。种子分布对 x 和 x′ 相同，所以对联合输出(a,y)仍有同一比值界。对替换一名用户的报告集合逐项应用该界，得到单轮 ε -LDP。该证明不要求哈希族均匀；均匀碰撞只用于估计器的 q=1/g、无偏性和方差口径。

A.3 支持引理。候选项 i 的来源支持集合至少含 t 个来源，其中至多 f 个来源是恶意的，因此诚实支持至少为 t−f；若诚实支持为 0 且 f<t，则总支持严格小于 t，与准入条件矛盾。该引理只约束候选集合，不涉及频率值、截尾权重或最终 Top-k 排序。

A.4 留一中位数引理。任意留出来源 s 后，peer 集合包含 n−1 个来源。若 f<(n−1)/2，即使被留出的是诚实来源，peer 中的诚实来源仍严格过半。因此 peer 中位数（偶数时取两个中间值的平均）位于诚实稠密值区间；peer MAD 不超过诚实值极差R_i，peer 方差中位数不超过诚实方差最大值V_i。较弱条件 f<(n+1)/2 不足以保证每个留一集合都保持诚实严格多数。

A.5 截尾上界引理。由 A.4，任意来源的 peer 位置中位数不超过M_i，MAD 换算后的鲁棒尺度不超过 1.4826R_i，peer 方差尺度不超过V_i，相对项不超过 ρ M_i。因此截尾上界不超过U_i。clip_floor=0 且输入非负时，诚实来源的截尾值满足 0≤$z_{h,i}$≤$v_{h,i}$≤M_i；恶意来源截尾后满足 0≤$z_{b,i}$≤U_i。缺失值填充只进入 peer 尺度统计，不改变最终融合缺失项取 0 的实现。

A.6 权重份额与影响界。对诚实来源 h，peer 权重中位数至少为 w，且 κ ≥1，所以ω_h=min(u_h, κ ·peer_median)≥w。对恶意来源 b，peer 权重中位数不超过 W，所以ω_b≤ κ W。由此恶意来源的实际权重份额α_F不超过 f κ W/((n−f)w+f κ W)=$\bar{\alpha}$。f=0 时

直接有S_i=S_i^H；以下设 f>0。将诚实来源按当前封顶权重归一化成S_i^H，将恶意来源归一化成A_i，则S_i=(1−α_F)S_i^H+$\alpha_F A_i$；由 0≤A_i≤U_i、0≤S_i^H≤U_i及α_F≤$\bar{\alpha}$，得到(1−$\bar{\alpha}$)S_i^H≤S_i≤(1−$\bar{\alpha}$)S_i^H+$\bar{\alpha}U_i$。S_i^H是当前攻击依赖输入中的诚实部分，不是无攻击反事实运行的分数。

A.7 条件核对。若切换到 public-context 分支、来源数少于 3、允许重复来源、方差为零或无穷、clip_floor 不为 0、κ<1，以上证明均不能直接套用。$\bar{\alpha}$=2/11 还需要 n=10、f=1、κ=2 且 W=w；相同样本数不等于相同权重。trimmed_frequency 的缺失补 0 和两端删除也没有继承本定理。

A.8 实验解释。四方法对照使用同一底层样本、相同 ε 和种子；PrivEdge 入口直接构造摘要对象，未测真实签名验证、账本拒绝和协议开销。正式运行采用五个种子，先对每个目标求种子均值，再以 2000 次 bootstrap 重采样目标；数据集目标共享来源区域，因此区间是有限实验网格上的经验区间，不能解释为独立总体的普遍置信区间。

表 A-1 证明条件与实现对应

条件	代码或实验对应	不覆盖
每人每窗口至多一条报告	由部署治理保证；代码仅接收报告条数	跨来源重复用户的并行组合
来源 ID 互异且每源一份摘要	准入检查与同源去重	重复来源冒充不同来源
context=None，n≥3，f<(n-1)/2	variance_weighted_capped 路径	public-context 或更高故障比例
clip_floor=0，方差有限正值，κ≥1	非负截尾与封顶权重	零方差、无穷方差或负截断下界

补充：OLH 概率与估计符号。下列等式在理想均匀哈希碰撞模型下给出 p、r、q 及反偏置计数口径；固定哈希种子的 ε-LDP 证明不要求该均匀碰撞假设。

$$\hat{C}_i = \frac{c_i - Nq}{p - q}, \quad p = \frac{e^{\varepsilon}}{e^{\varepsilon} + g - 1}, \quad r = \frac{1}{e^{\varepsilon} + g - 1}, \quad q = 1/g$$

$$f_i = \max(0, \hat{C}_i)/N$$

需要区分隐私性和估计性。固定哈希种子时，随机响应的似然比给出 ε -LDP；哈希碰撞近似均匀才用于把非目标概率写成 q 并支持无偏估计。当前端到端发布实现固定采用 SplitMix64 fallback 哈希，仓库没有证明该哈希族具有通用均匀碰撞性质，因此无偏性和方差公式以理想碰撞模型为理论口径，实际实现效果由登记实验衡量。发布端的候选筛选、非负截断、签名和网关融合都是已扰动报告的后处理；经过数据依赖筛选后，最终 Top-m 频率不能继续表述为严格无偏。

附录 B 结论与证据定位

本索引只保留阅读正文所需的主要结论入口。每个编号对应不可覆盖的原运行与核对产物；全历史条目、修复失败现场和跨机回传清单见《工程验证与历史记录附件》。统计复算核对已有输出，不证明历史运行前的冻结时序。

表 B-1 正文结论与证据入口

正文结论	登记证据	读取与解释范围
两层防御的攻击变化	E9；3.4.2	SECURITY_V2 原 CSV 及 summary；五种子和全部目标；保留未达预注册条件。
隐私效用和参数	E10 、 E14 ；3.4.3	UTILITY_V1 及封顶等价记录；拒答计 0，不能外推业务收益。
权重封顶复验	E13；3.4.2	SECURITY_V4 新种子，同数据及攻击族；不是新外部数据集。
四方法相对表现	E28；3.4.1	三组 compare_v1 原件与 review；8640 行、216 方法单元；描述性比较。
符号协议性质	E16；2.6.3	ProVerif 模型、查询、可达性与四个负对照；不含预算数值及统计防御。
旧管线通信开销	E6；3.4.7	m=20、合成 Zipf 数据；旧单机微基准。
当前程序验证	E34；3.4.5	backend_validation/20261017_review_delivery；测试、请求、截图与程序指纹。

四方法证据由 GET /api/evidence/a8/descriptive 读取，严格预注册绑定入口单独保留。表格、图与页面均读取规范摘要，并核原件与派生物指纹；哈希一致不补足冻结缺口。既有算法主运行的 4,176 个统计字段、E28 的 35,815 个字段复算均无差异，细目见工程附件。

附录C 当前程序运行与复现

C.1 程序版本与三步启动

当前冻结程序为PrivEdge_评审演示与复现_E34_20261017.zip,大小66,784,721字节，SHA-256为4c5429d52c847319851d0bd664be76a5a5be1ed11a88243ed3612310a29a44fa。包内6,064项载荷及package_manifest.json已逐项核对，并在含中文及空格的新解压目录自检通过。程序包括隔离CPython、现成前端、三套标准表、既有实验、38项Python依赖以及ProVerif 2.05和完整同版工具源码;最终实体第二电脑验收仍需另行完成。

第一步，将Windows x64程序包完整解压到本地可写目录，保留目录结构。第二步，运行“验证程序.cmd”核对载荷指纹。第三步，运行“启动程序.cmd”，进入其打开的本机页面。便携包包含隔离Python和锁定依赖,运行现成页面无需安装Python或Node.js。

运行“运行测试.cmd”可复查包内自动回归。服务只监听本机；关闭后重新启动会重建当前内存账本与密钥。源码开发与便携运行是不同入口：需要修改源代码时按照程序README及依赖锁重建，修改前端后重新构建静态文件。

C.2 统计复现的起点与限制

统计复现以第三章列出的三套标准表为起点，先核对domain.json所记录的数据哈希，再按对应预注册方案在新运行目录执行；不得覆盖旧runs、review或原始数据。每次保留参数、种子、代码和数据指纹、环境、时间及产物清单。

“快速核心统计复现.cmd”执行三数据、首目标、首种子的小网格；“完整A8四方法重算.cmd”给出全部目标、种子和攻击场景的运行入口。快速网格216行已执行并独立复核，完整8,640行网格仅核对执行计划，未在E34完整重跑。所有新结果写入独立运行及reproduction_outputs目录，不改写E28或取得确认性资格。

“重跑形式化验证.cmd”调用随包ProVerif 2.05，主模型与四个负对照已经实际求解。“从历史证据重建图表.cmd”从已有统计重绘五张实验图及两张架构、协议图，已生成七组PNG/SVG；重绘不等于重新计算统计实验。图表依赖、制图源码、工

具许可及 ProVerif 完整源码随包，运行入口无需联网安装。

每次复现保留命令、环境、输入指纹、独立日志、状态与输出索引，并在结束后复查登记载荷未被改写。完整原始下载和预处理依赖链尚未独立重建；现有离线复现起点是随包标准表，不能仅据研究脚本存在认定原始数据至结果已经复现。

最终第二电脑验收须记录 ZIP 指纹、实体设备、系统版本、测试日志、三数据五页操作及失败复测，并由实际执行人确认。历史运行命令、安装和异机回传记录见工程附件；同机新目录解压不代替实体异机验收。

附录 D 来源与第三方许可

D.1 原创范围与代码来源

本队自有原始研究代码的原样内核与新增工程层分开登记。OLH、MGA 和 Ed25519[11]等既有方法按实际使用引用，不列为本队独创；文件一致只证明副本一致，不独立证明作者和权利归属。

表 D-1 实现来源与本项目工作

部分	来源或本项目工作	复核依据
研究内核	原样保留 fusion、metrics、ldp_protocols 等 9 个研究文件	research_core 清单及原始研究快照
OLH 工程接口	分离扰动、聚合及支持矩阵计算，固定备用哈希	ldp.py 及逐位一致性回归测试
安全与决策层	摘要信封、角色密钥、预算账本、网关、截尾、支持规则、权重封顶与三态	envelope、keys、ledger、gateway、robust、decision 等实现
实验及演示	预注册运行器、图表、形式模型、FastAPI 接口与 React 页面	experiments、formal、server、web/src
验证与复现	验收测试、证据复算、候选修复复测、运行说明及许可归档	qa/b_20261013、qa/b_retest_20261013 及新增测试文件

已核对的 OLH 移植上游为 Tianhao Wang 维护的 LDP_Protocols，并保留 MIT 许可、署名和固定核对快照。核对快照 commit 为 f7252b07733dc0e100e2f077218ab2d35d3519d5，不等于当年移植版本已确认；历史来源包或版本仍需提供者确认。研究内核原字节保持不变，不笼统称全部代码按论文独立实现。

成员实际贡献、权利归属及原创性声明须本人确认和签署。AI 辅助参与代码修改、验证脚本、证据核对与报告整理，不能替代成员的实际贡献或独立人工验收。正式声明另按当届模板提交。

D.2 数据来源与许可

表 D-2 数据来源与许可核实状态

数据或材料	已核对的公开来源与许可	实际状态与边界
美团 TRD	Zenodo 8025855，Liu Yijian，版本 1.0；官方 API 的 metadata.license.id 为 cc-by-4.0	已归档 CC BY 4.0 字段及许可原文；美团向上传者授权的独立依据仍待确认。
Olist	Kaggle 的 olistbr/brazilian-ecommerce；官方元数据 ownerName 为 Olist，licenseName 为 CC BY-NC-SA 4.0	官方字段和许可原文已归档；保留历史原包核对记录，本轮没有重新下载全部原始数据。
Massive-STEPS	官方仓库 cruiseresearchgroup/Massive-STEPS；当前代码为 Apache-2.0	当前代码许可已归档，不能代替项目冻结数据许可；实际下载版本及上游字段链仍须补证。
Semantic Trails	Figshare 官方 API 返回 v2，DOI 10.6084/m9.figshare.7429076.v2，license.name 为 CC0	数据许可字段及原文已取得；尚需对应本项目确切原始文件版本，代码许可另行对待。
OSM/ohsome 上下文	OpenStreetMap 官方版权页标明 ODbL；经 HeiGIT ohsome 提取，既有缓存保留 OSM 署名	正式清单已补© OpenStreetMap contributors、ODbL 链接及服务来源，并随包保存完整许可。

三套标准事件表及部分公开上下文随包，原始下载不随包；过滤或去标识不改变来源。TRD 注明首单、品类和商圈转换，不写成已取得美团直接授权；Olist 保留非商业、署名与相同方式共享说明。OSM 上下文保留“© OpenStreetMap contributors”、ODbL 1.0 及 HeiGIT ohsome 来源。

Massive-STEPS 另涉及 Foursquare Open Source Places，当前代码许可和 CC0 元数据不能确认全部冻结输入。已有 Olist、Massive 和 TRD 研究来源文件的定位及指纹记录，但完整下载处理链与标准表重建尚未独立验证。

D.3 分发组件与未完成确认

当前程序按实际载荷附带Python运行时、38项Python依赖、前端组件与ProVerif 2.05 的许可材料，制图依赖也纳入离线环境。ProVerif 的工具目录、许可与完整同版源码归档随包；打包、启动及复现入口保留源码。旧 31 包及 119 项许可核查记录在工程附件中按历史范围保留，不作为新载荷的完整清单。

仍需本人确认成员作者与贡献、TRD 上游授权依据及 Massive 冻结输入链。已定位的研究脚本不再视为本机缺失，但脚本存在尚不足以证明完整原始输入链或权利归属。最终分发应按实际载荷核对许可，不把运行通过作为授权证明。